

CEN429 Dönem Projesi – Proje Rehberi

CEN429 Güvenli Programlama (eski kodu CE407) · 2026–2027 Güz

Bu projede, seçtiğiniz bir uygulamayı **sertifikasyon sürecinden geçiyormuş gibi** tasarlayıp geliştireceksiniz: bir **C++ konsol uygulaması** ve onun güvenliğini sağlayan bir **dinamik kütüphane (DLL/.so)**. Amaç, dönem boyunca öğrendiğiniz güvenlik yöntemlerini **tek bir üründe** birleştirmek ve hepsini bir **güvenlik kılavuzuyla** (S0–S17) belgelemektir.

Dil ve araçlar

C++ (DLL/.so) · CMake/CTest · SQLite ·
[SoftHSM/PKCS#11](#) · OpenSSL

Takım

En çok 3 kişi (tek başınıza da olur) · bir konuyu yalnız bir takım alır · 3. haftadan sonra takım değişmez

Vize kontrolü

a. hafta (30.10.2026) · RAP1 — ürünün ilk yarısı

Final kontrolü

a. hafta (25.12.2026) · RAP2 — tam ürün + test sonuçları

Kısaca

- **Takım:** en çok 3 kişi (tek başınıza da yapabilirsiniz); bir konuyu yalnız bir takım alabilir. 3. haftadan (04.10.2026) sonra takım değiştirilemez.
- **Dil/araçlar:** C++ (DLL/.so), CMake/CTest, SQLite, [SoftHSM/PKCS#11](#), OpenSSL.
- **İki teslim: Vize (RAP1)** — ürünün ilk yarısı; **Final (RAP2)** — tam ürün + test sonuçları.
- **Teslimin kalbi:** kodun yanında, sertifikasyon belgesi gibi yazılmış **güvenlik kılavuzu** (S0–S17).
- Bütün veriler **sentetiktir**; depoda gerçek sır, anahtar ya da kişisel veri bulunmaz.
- Ayrıntılı puanlama anahtarı ve kanıt şablonları Microsoft Teams'te paylaşılabilir; bu sayfadaki kriterler ve puanlar bağlayıcıdır.

1. Takvim

Hafta	Tarih	Etkinlik
3. hafta sonu	04.10.2026	Konu ve takım seçiminin son günü
4. hafta	09.10.2026	Proje planının ders sorumlusuna onaylatılması
7. hafta	30.10.2026	Vize gösterimi + ara rapor (RAP1)
8. hafta	31.10–08.11.2026	Quiz-1 (1–6. haftalar)
15. hafta	25.12.2026	Final gösterimi + final raporu (RAP2)
16. hafta	04–17.01.2027	Quiz-2 (9–14. haftalar)

Haftalık ders içeriğinin tamamı için bkz. [izlence](#). Tarihler değişirse duyuru ders sınıfından yapılır.

2. Değerlendirme yapısı



Ağırlıklar

- Vize = $0,6 \cdot \text{RAP1} + 0,4 \cdot \text{Quiz-1}$ · Final = $0,7 \cdot \text{RAP2} + 0,3 \cdot \text{Quiz-2}$**
- Başarı notu = $0,4 \cdot \text{Vize} + 0,6 \cdot \text{Final}$**
- RAP1 (7. hafta):** ürünün ilk yarısı (S2–S5 + temel korumalar). **RAP2 (15. hafta):** tam ürün + S16 sonuçları.

Öğrenme çıktıları (ÖÇ)

ÖÇ	Tanım	Bloom düzeyi	Bilgi/Beceri	RAP1	RAP2
ÖÇ.1	Yaygın yazılım güvenlik açıklarını (arabellek taşması, enjeksiyon saldırıları, bellek sızıntıları vb.) tanımlar ve sınıflandırır.	Anlama	BİLGİ	✓	✓
ÖÇ.2	Hassas verileri korumak için temel şifreleme yöntemlerini ve güvenli iletişim ilkelerini (SSL/TLS) açıklar.	Anlama	BİLGİ	✓	✓
ÖÇ.3	Kod sağlamlaştırma tekniklerini (girdi doğrulama, güvenli bellek yönetimi, RASP, kod gizleme) açıklar ve uygular.	Uygulama	BECERİ	✓	✓
ÖÇ.4	Şifreleme ve kimlik doğrulama mekanizmalarını kullanarak güvenli iletişim kanalları kurma ilkelerini açıklar.	Uygulama	BECERİ	✓	✓
ÖÇ.5	Güvenli yazılım tasarımı ilkeleriyle (en az ayrıcalık, savunma derinliği vb.) bir koruma planı oluşturur.	Sentez	BECERİ	✓	✓
ÖÇ.6	Yazılım güvenlik açıklarını tespit etmek için temel güvenlik incelemesi ve açık değerlendirmesi yapar.	Analiz	BECERİ	✓	✓
ÖÇ.7	Güvenli programlama standartlarını (ör. ETSI, EMV, FIPS) ve sızma testi planlaması ilkelerini bilir.	Anlama	BİLGİ	✓	✓

Her iki kontrol de bütün öğrenme çıktılarına dokunur; RAP1 temel/erken düzeyi, RAP2 ileri düzeyi ve tam ürünü ölçer.

3. Araçlar ve kurulum

Araç	Ne için	Çıktı	Teslim koşulu
C++ derleyicisi (GCC/Clang/MSVC)	Konsol uygulaması + DLL/.so derlemesi	Çalışan binary	Sürümde hatasız derlenir
CMake + CTest	Derleme sistemi + birim testi	Test raporu	CI'de yeşil
SQLite	Beklemedeki veri deposu	.db şeması	AES-GCM ile şifreli kayıt
SoftHSM / PKCS#11	Anahtar sarma/saklama benzetimi	Anahtar deposu yapılandırması	Kritik anahtarlar sarılı tutulur
OpenSSL	Kriptografi, TLS, imzalama	Kütüphane bağlantısı + sertifikalar	Doğru algoritma/kip/dolgu
Doxygen	Kod belgelendirmesi	PDF/HTML çıktısı	Şablonun ürettiği biçimde teslim
Git / GitHub	Sürüm kontrolü, iş birliği	Commit geçmişi, çekme isteği (pull request)	Özel depo, her iki üyenin de commit'i görünür
GitHub Actions	Sürekli entegrasyon (CI)	Yeşil derleme/test rozeti	Birleştirmeden önce CI yeşil

Şablon deposu: [ucoruh/cpp-cmake-ctest-template](https://github.com/ucoruh/cpp-cmake-ctest-template) → fork edip `cen429-proje-ad-soyad-cpp` adıyla adlandırın, **özel (private)** yapın, ders sorumlusunu ve varsa takım arkadaşınızı **işbirlikçi (collaborator)** olarak ekleyin.



Şablonu tam kullanın

Şablon; derleme, **CTest ile birim testi**, dokümantasyon üretimi, test/dokümantasyon kapsamı ölçümü ve paketlemeyi sağlar. Şablon standartlarına uymayan teslimler kabul edilmez. Sürüm (release) üretin; sürüm kimliği ve özet değerlerini kaydedin (12. hafta TOE kimliği).

Proje düzeni:

- `lib/` — güvenlik kütüphanesi (DLL/.so): kriptografi, RASP, kod gizleme, veri koruma fonksiyonları.
- `app/` — konsol uygulaması: kütüphaneyi kullanan kullanıcı arayüzü.
- `test/` — CTest birim testleri (kripto ve koruma fonksiyonları).

Geliştirme ortamı kurulumu ve ön bilgi için bkz. [Ön gereksinimler](#).

4. Konu seçimi

Proje konuları bu sayfanın sonundaki **Ek — Proje konuları listesi** bölümündedir (100 konu). Her konu kutusunda uygulamanın kısa tanımı, temel özellikleri, **korunacak varlıklar** ve o konuda **öne çıkan güvenlik gereksinimleri** (5.

bölümdeki maddelerle) verilmiştir.

Nasıl seçilir?

1. Aşağıdaki (sayfa sonundaki) listeyi inceleyin ve bir konu seçin.
2. Seçiminizi Microsoft Teams'teki **takım ve konu tablosuna** yazın. **Bir konuyu yalnız bir takım alabilir**; tabloya ilk yazan takım alır.
3. Proje planınızla (3. bölüm araçlar ve kurulum ile birlikte hazırlanan plan) birlikte ders sorumlusuna onaylatın; onaydan sonra konu değiştirilmez.

- a. bölümdeki 15 gereksinimin **hepsi** her projede geçerlidir; konu kutusundaki "öne çıkan gereksinimler", o konuda en doğal ve en çok puan getiren uygulama yerlerini gösterir.
- Listede olmayan bir fikriniz varsa, gereksinimleri anlamlı biçimde uygulayabileceğiniz kadar zenginse ders sorumlusunun onayıyla seçebilirsiniz.
- Bu dersi tekrar alıyorsanız **önceki projenizden farklı** bir konu seçin.

5. Gereksinimler

Her gereksinimin yanında **hangi haftada işlendiği** ve **kılavuzda hangi bölüme (S)** yazılacağı verilmiştir. Aşağıdaki 15 gereksinim, rubrikteki karşılıklarıyla (bkz. 8. Rubrikler) uyumlu olacak şekilde vize ve final kapsamına ayrılmıştır; bazı gereksinimlerin ileri düzey yönleri ilerleyen haftalarda derinleşir. Her maddeyi ya **karşılaysın** ya da **gerekçeli olarak devredin/kapsam dışı bırakın** (13. hafta, S14).

5.1 Vize kapsamı (RAP1)

4.1 Geliştirme ortamı güvenliği · (Hafta 1, 12 · S13)

İlgili haftalar: [Hafta 1](#) · [Hafta 12](#)

- Yazılım geliştirme akışı ve **değişiklik yönetimi** (temel çizgi → talep → sınıflandırma → onay → yayın → doğrulama).
- **Git** ile sürüm kontrolü; erişim kaydı; imzalı sürüm.
- Geliştirme bilgisayar/sunucu güvenliği (kısa politika).

4.2 Kullanımdaki veri güvenliği · (Hafta 3, 6 · S7)

İlgili haftalar: [Hafta 3](#) · [Hafta 6](#)

- Bellekteki hassas veri kullanımdan sonra **güvenli silinir** (`memset_s` benzeri).
- Çalışma zamanı veri koruması (gölge kopya/bütünlük — 6. hafta).

4.3 Aktarımdaki veri güvenliği · (Hafta 3, 10 · S6, S11)

İlgili haftalar: [Hafta 3](#) · [Hafta 10](#)

- **TLS 1.3**; sertifika zinciri + **SAN** doğrulaması; **sabitleme (pinning)** + yedek pin.
- Şifrelenmiş **oturum anahtarı**; **cihaz/sürüm bağlama**; bütünlük + kimlik doğrulama; sunucu doğrulama kodu.

4.4 Beklemedeki veri güvenliği · (Hafta 3, 10, 11 · S8)

İlgili haftalar: [Hafta 3](#) · [Hafta 10](#) · [Hafta 11](#)

- Dosya/DB şifreleme **AEAD** (AES-GCM); nonce tekrarsız.
- Hassas anahtarlar için **whitebox** ya da **SoftHSM/PKCS#11**; kararın **gerekçesi** (11. hafta).

4.8 Arayüz tanımları ve korunması · (Hafta 1, 4 · S3, S6)

İlgili haftalar: [Hafta 1](#) · [Hafta 4](#)

- Tüm arayüzler erişim kontrolü + kimlik doğrulama ile korunur; girdi **güven sınırında** doğrulanır.

4.9 Kod sağlamlaştırma · (Hafta 4, 9, 14 · S9)

İlgili haftalar: [Hafta 4](#) · [Hafta 9](#) · [Hafta 14](#)

- Opak döngü/yüklem, ad/dosya/dize/aritmetik gizleme, opak boolean, sahte işlem/ölü dal, **kontrol akışı düzeltirme** + rastgele çıkış, sürümde **log kapalı**. Maliyeti **ölçün** (9/14. hafta demoları).

4.10 RASP · (Hafta 6 · S10)

İlgili haftalar: [Hafta 6](#)

- Checksum bütünlük denetimi, çağırın uygulama hash/imza doğrulaması, kök/emülatör tespiti, **hook/anti-debug**, kurcalama (tamper) tespiti + yanıt, kontrol akışı sayacı.

4.11 Bellek koruması · (Hafta 4 · S9)

İlgili haftalar: [Hafta 4](#)

- Derleyici/OS korumaları (yığın koruyucu, PIE, RELRO, NX, CFI); hassas veri kullanım sonrası temizlenir.

5.2 Final kapsamı (RAP2)

4.5 Statik varlıkların korunması · (Hafta 1, 4, 9 · S5, S9)

İlgili haftalar: [Hafta 1](#) · [Hafta 4](#) · [Hafta 9](#)

- Gizli anahtarlar, özet değerleri, kaynak kodu, kaynaklar: şifreleme + erişim kontrolü + gizleme.

4.6 Dinamik varlıkların korunması · (Hafta 3, 6 · S5, S8)

İlgili haftalar: [Hafta 3](#) · [Hafta 6](#)

- Cihaz/uygulama parmak izleri, oturum verileri, dinamik anahtarlar şifrelenir.

4.7 Varlık yönetimi · (Hafta 1, 3, 13 · S5)

İlgili haftalar: [Hafta 1](#) · [Hafta 3](#) · [Hafta 13](#)

Her varlık için: **ad**, **açıklama**, **konum** (tablo/sütun), **kaynak**, **boyut**, **oluşturma/silme zamanı**, **varsayılan**, **koruma şeması** (C/I/I+).

4.12 Kriptografi ve sertifikalar · (Hafta 3, 10 · S8, S11)

İlgili haftalar: [Hafta 3](#) · [Hafta 10](#)

- Doğru algoritma/kip/dolgu; imza doğrulaması (==1 , sürüm kapsamı); SSL/TLS + pinning + karşılıklı kimlik doğrulama.

4.13 Sertifikasyon ve sızma testi planı · (Hafta 12, 13 · S16, S14, S17)

İlgili haftalar: [Hafta 12](#) · [Hafta 13](#)

- Standart eşlemesi (ETSI/EMVCo/GSMA/PCI/MASVS); **sızma testi planı** (kapsam, kurallar, yöntem, test kartı) ve **sonuçları**; saldırı potansiyeli + CVSS.

4.14 Binary uygulama koruması · (Hafta 6, 9, 11, 14 · S9, S10, S15)

İlgili haftalar: [Hafta 6](#) · [Hafta 9](#) · [Hafta 11](#) · [Hafta 14](#)

- **Tespit** (checksum, anti-debug, emülatör), **savunma** (gizleme, dize/kaynak şifreleme, çağrı gizleme), **caydırma** (yanıt/kapanma politikası).

4.15 OWASP ve derleme/dağıtım hattı · (Hafta 5, 14 · S13, S15)

İlgili haftalar: [Hafta 5](#) · [Hafta 14](#)

- OWASP MASVS/ASVS ilkeleri; **SBOM** (CycloneDX) + bağımlılık taraması; gizleme+imzalama içeren derleme hattı.

5.3 Her iki kontrolde ortak kurallar

- Değerler **sentetik** olmalı; depoda gerçek sır, anahtar ya da kişisel veri **bulunmaz**.
- Her gereksinim maddesi kod içinde **görülebilir** olmalı ve güvenlik kılavuzunun ilgili S bölümünde **belgelenmelidir**; belgelenmeyen bir uygulama karşılanmamış sayılır.
- Bir gereksinim karşılanamıyorsa **gereğesiyle** S14 (varsayımlar ve devredilenler) bölümüne yazılır; sessizce atlanamaz.
- Uygulama yalnız kendi bilgisayarınızda (localhost) çalışır; başka bir sisteme veya veriye zarar vermez.

6. Teslim edilecekler

6.1 Teslim tablosu

#	Teslim	Biçim	Kural
1	Kaynak kod	Git deposu (fork)	CMake/CTest, C++ DLL/.so + SQLite + SoftHSM entegrasyonu; her committe iki üye de görünür
2	Birim testleri + CI kaydı	CTest raporu + CI günlüğü	Kripto ve koruma fonksiyonları test edilir; CI yeşil olmadan birleştirme yok
3	Güvenlik kılavuzu (S0–S17)	.docx / .pdf	Vize: S0–S5 taslak · Final: S0–S17 tam, sertifikasyon belgesinin küçültülmüş modeli
4	Test sonuçları (S16)	Kılavuz bölümü	Yalnız final; plan değil, gözlener sonuçlar
5	Uyum matrisi (S17) + devredilen gereksinimler (S14)	Kılavuz bölümü	Yalnız final; her devredilen madde gerekçeli
6	SBOM + bağımlılık taraması	CycloneDX dosyası	Yalnız final; 4.15 ile birlikte teslim edilir
7	Sürüm (release)	Git etiketi	Vize: midterm-v1.0 · Final: final-v1.0
8	Gösterim	Canlı sunum (~10 dk)	Vize: 7. hafta · Final: 15. hafta

6.2 Güvenlik kılavuzu bölümleri (S0–S17)

No	Bölüm	No	Bölüm
S0	Kapak, sürüm geçmişi	S9	Kod sağlama/laştırmaya (ileri)
S1	Kapsam, kısaltmalar, kaynaklar	S10	RASP + tepki politikası
S2	Ürün ve mimari	S11	Güvenli iletişim (TLS)
S3	Arayüzler	S12	Raporlama/günlüklenme
S4	Tehdit modeli (STRIDE, ağaç)	S13	Geliştirme süreci, SBOM, değişiklik
S5	Varlık listesi + koruma	S14	Varsayımlar ve devredilenler
S6	Kimlik/bağlama	S15	Derleme, imzalama, dağıtım hattı
S7	Veri güvenliği + kabuk matrisi	S16	Güvenlik testi ve sonuçları
S8	Kripto, anahtar yaşam döngüsü	S17	Gereksinim uyum matrisi

6.3 Tek ZIP arşivi yapısı

```

cen429-vize-ad-soyad.zip
├── cen429-proje-ad-soyad-cpp/
│   ├── lib/
│   ├── app/
│   ├── test/
│   ├── docs/
│   ├── security-guide/
│   │   └── cen429-guvenlik-kilavuzu-ad-soyad.docx
│   ├── sbom/
│   ├── test-coverage/
│   └── README.md
└── # final teslimi: cen429-final-ad-soyad.zip
    # GitHub deposunun klonu (.gitignore uygulanmış)
    # güvenlik kütüphanesi (DLL/.so)
    # konsol uygulaması
    # CTest birim testleri
    # Doxygen çıktısı
    # S0–S17 güvenlik kılavuzu
    # CycloneDX SBOM + bağımlılık taraması (final)
    # CTest kapsam raporu

```

Adlandırma: depo `cen429-proje-ad-soyad-cpp`; arşiv `cen429-vize-ad-soyad.zip` / `cen429-final-ad-soyad.zip`; güvenlik kılavuzu dosyası `cen429-guvenlik-kilavuzu-ad-soyad.docx`. Rapor/kılavuzun kapak sayfasında **GitHub deposu bağlantısı** bulunur.

7. Takım çalışması ve mühendislik uygulamaları

- **GitHub Flow:** `main` dalı korumalıdır, doğrudan commit yapılmaz; her iş için ayrı bir özellik dalı (feature branch) açılır, birleştirme **çekme isteği (pull request)** ile yapılır.
- **Commit mesajı kuralı:** **Conventional Commits** biçimi, ör. `feat(crypto): add AES-GCM wrapper`, `fix(rasp): correct debugger detection`, `test(hash): add SHA-256 vectors`.
- **Çekme isteği + inceleme:** her PR en az bir takım arkadaşınca **incelenir (code review)**; açıklamada ne değiştiği ve nasıl test edildiği yazılır.

- **Issues + Projects panosu:** her iş bir GitHub Issue'dur; pano sütunları Backlog → In Progress → In Review → Done şeklinde takip edilir.
- **CI yeşil olmadan birleştirme yok:** GitHub Actions derleme + CTest çalıştırır; kırmızı CI ile `main` 'e birleştirme yapılmaz.
- **Sürüm etiketleri:** vize teslimi `midterm-v1.0`, final teslimi `final-v1.0` olarak etiketlenir (release).
- **"Bitti" tanımı (Definition of Done):** kod derleniyor ve çalışıyor · yeni genel fonksiyonlar için birim testi var · kapsam düşmedi · PR incelendi ve onaylandı · CI yeşil · güvenlik kılavuzunun ilgili S bölümü güncellendi.

8. Rubrikler

Her kriter **1–5** düzeyinde puanlanır ve puan = (düzey ÷ 5) × kriter puanı olarak hesaplanır.

8.1 Başarı düzeyleri

Düzey	Anlamı
5 – Mükemmel	Kapsamdaki her şey çalışıyor, test edilmiş ve belgelenmiş; gösterimde adım adım açıklanabiliyor
4 – İyi	Küçük eksikler ya da uç durum hataları var; genel olarak tamam ve test edilmiş
3 – Yeterli	Temel işlemler çalışıyor; testlerde, belgelerde ya da ölçümlerde belirgin eksikler var
2 – Zayıf	Derleniyor ama işlemlerin çoğu yanlış ya da eksik; açıklama zayıf
1 – Kanıt yok	Teslim edilmemiş ya da çalışmıyor

8.2 RAP1 – Vize kontrolü rubriği (7. hafta, 100 puan)

#	Kriter	Kapsam	Öç	Puan
1	Tehdit modeli ve varlık listesi	S4, S5	Öç.1, Öç.5	15
2	Veri güvenliği: aktarım, bekleme, kullanım	4.2–4.4; S7, S8	Öç.2, Öç.4	20
3	Kod sağlama ve bellek koruması	4.9, 4.11; S9	Öç.3	20
4	RASP ve tepki politikası	4.10; S10	Öç.3	10
5	Geliştirme ortamı ve değişiklik yönetimi	4.1; S13	Öç.5	10
6	Birim testleri ve CI	—	Öç.6	10
7	Güvenlik kılavuzu (S0–S5) ve gösterim	—	Öç.7	15
Toplam				100

8.3 RAP2 – Final kontrolü rubriği (15. hafta, 100 puan)

#	Kriter	Kapsam	ÖÇ	Puan
1	Kriptografi ve sertifikalar	4.12; S8, S11	ÖÇ.2, ÖÇ.4	15
2	Binary uygulama koruması, gizleme ve çeşitlendirme	4.14; S9, S10, S15	ÖÇ.3	20
3	Varlık yönetimi ve dinamik varlıklar	4.5–4.7; S5	ÖÇ.5	10
4	Güvenlik testi ve gözlenen sonuçlar	4.13; S16	ÖÇ.6	20
5	Standartlar, uyum matrisi, devredilenler	S1, S14, S17	ÖÇ.7	15
6	OWASP, SBOM ve derleme/dağıtım hattı	4.15; S13, S15	ÖÇ.1, ÖÇ.5	10
7	Rapor, sunum ve gösterim	—	ÖÇ.7	10
Toplam				100

Her satır bir **kanıt** ister: "karşılandı" diyen satırın kanıtı yoksa karşılanmamış sayılır (13. hafta).

9. Kabul koşulları

⚠ Teslim kabul edilmez, eğer...

- GitHub deposu yoksa, **özel (private)** değilse ya da takım üyelerinin commit'i görünmüyorsa,
- gereksinimlerin karşılanma oranı asgari eşiğin altındaysa,
- depoda ya da arşivde **binary dosyalar** (derlenmiş `.exe` / `.dll` / `.so`) varsa,
- sürüm (release) üretilmemişse,
- uygulama Windows ya da WSL/Linux'ta **derlenmiyor/çalışmıyorsa**,
- depoda gerçek sır, anahtar ya da kişisel veri varsa (bütün değerler sentetik olmalı),
- **intihal** tespit edilmişse.

10. Gösterimde sorulacaklar

- **Git/GitHub:** Şablonu doğru adla fork ettiniz mi? Depo özel mi, ders sorumlusu işbirlikçi mi? Her iki üyenin de commit'i var mı? Dal (branch) kullanıldı mı, birleştirme (merge) nasıl yapıldı?
- **Kurulum-derleme:** Uygulamayı ve kütüphaneyi Windows'ta ve WSL/Linux'ta derleyin; `lib` / `app` / `test` ayrımını ve bağımlılıklarını gösterin.
- **Konu (satır satır):** Seçtiğiniz güvenlik gereksinimini (ör. AES-GCM ile şifreleme, RASP kurcalama denetimi, kod sağlama/şifreleme dönüşümü) kodda satır satır açıklayın; bellek/veri akışını çizerek gösterin.

- **Test ve belge:** Birim testlerini ve kapsam raporunu açın; güvenlik kılavuzunda ilgili S bölümünü gösterin.
- **Dosya/veri işlemleri:** Bir kayıt ekleyin, programı kapatıp yeniden açın, verinin şifreli olarak geri geldiğini gösterin.
- **Programlama:** Bellek yönetimi, işaretçiler, derleyici/OS korumaları (stack canary, ASLR, NX, CFI), hata ayıklayıcıda (debugger) değişken ve yığın (stack) inceleme.

11. Mesleki sorumluluk ve akademik dürüstlük

- Teslim ettiğiniz her satırı **açıklayabilmelisiniz**; gösterimde takımın her üyesine soru sorulabilir.
- Başkasının kodunu/metnini kullandıysanız **kaynağını belirtin**; lisans uyumluluğuna dikkat edin.
- Bütün örnekler ve değerler **sentetik** olmalıdır; gerçek kişisel veri kullanılmaz.
- **İntihal** ve izinsiz kopyalama başarısızlık nedenidir; benzerlik denetimi yapılabilir.
- Takım içi katkı, commit geçmişinden izlenir; başkası adına commit atmak (hayalet commit) intihal sayılır.



Güvenli ve yasal çerçeve

Sızma testi yalnız **kendi** projeniz üzerinde yapılır. Örnekler ve değerler **sentetik** olmalı; hiçbir gerçek sır, anahtar ya da kişisel veri depoya girmemeli. Uygulamanız başkasının sistemine/verisine zarar vermemeli.

12. Sık sorulan sorular



Takımı tek başıma kurabilir miyim?



Evet. Takım en çok 3 kişidir; tek başınıza da yapabilirsiniz. Takımlar 3. haftanın sonunda (04.10.2026) kesinleşir ve sonra değiştirilemez. Gereksinimler ve rubrik değişmez.



Konumu onaydan sonra değiştirebilir miyim?



Hayır. Konu, proje planıyla birlikte onaylandıktan sonra değiştirilmez. Değişiklik gerekiyorsa ders sorumlusuyla görüşün.



Bir gereksinimi tam karşılayamazsam ne olur?



Gerekçenizi güvenlik kılavuzunun S14 (varsayımlar ve devredilenler) bölümüne yazarak devredebilir ya da kapsam dışı bırakabilirsiniz (13. hafta). Sessizce atlanan bir madde karşılanmamış sayılır.



RAP1'de eksik kalan bir gereksinim RAP2'de tamamlanabilir mi?



Evet, final kapsamı tam ürünü kapsar ve eksikler tamamlanabilir; ancak RAP1 puanı gösterim anındaki duruma göre verilir ve sonradan güncellenmez.

? Güvenlik kılavuzunu hangi biçimde teslim ediyoruz?

.docx ya da .pdf olarak, sertifikasyon belgesinin küçültülmüş bir modeli gibi, S0–S17 bölümleriyle. Vizede S0–S5 taslağı, finalde S0–S17'nin tamamı beklenir.

? Geç teslim kabul edilir mi?

İzlenedeki kurallar geçerlidir: geç teslim kabul edilmez. Beklenmedik bir durum varsa en kısa sürede ders sorumlusuna bildirin.

? Ayrıntılı puanlama anahtarını nereden bulabilirim?

Bu sayfadaki 8. bölümde kriterler, kapsam ve puanlar verilmiştir; ek kanıt şablonları ve açıklamalar gerekirse Microsoft Teams'te paylaşılır.

Ek – Proje konuları listesi

Aşağıdaki konulardan birini seçin (bkz. 4. Konu seçimi). Konular dört gruba ayrılmıştır: **ödeme ve ticaret (01–25)**, **sağlık, eğitim, kamu ve kimlik (26–50)**, **medya, lisans, iletişim ve yazılım tedarik zinciri (51–75)**, **IoT, endüstri, ulaşım ve kurum (76–100)**. Bütün veriler sentetiktir; sunucu tarafı yalnız kendi bilgisayarınızda (localhost) çalışan bir benzetimdir.

01 – Çevrimdışı Ödeme Cüzdanı

Kısa tanım: Kullanıcının internet olmadan küçük ödemeler yapabildiği bir cüzdan. Bakiye ve tek kullanımlık ödeme anahtarları cihazda durur; bağlantı gelince işlemler sunucuyla eşleşir. Cihaz sahibi aynı zamanda olası saldırgandır: bakiyeyi artırmak ya da aynı anahtarı iki kez harcamak ister.

Temel özellikler: Hesap açma ve PIN · Bakiye görüntüleme · Çevrimdışı ödeme (QR/kod) · İşlem geçmişi · Sunucuyla eşleme

Korunacak varlıklar:

- Tek kullanımlık ödeme anahtarları – **C, I+**
- Bakiye ve işlem sayacı – **I+** (geri sarılmamalı)
- PIN doğrulama verisi (özet) – **C, I**
- Oturum anahtarı – **C**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** bakiye ve anahtarlar SQLite'ta AES-GCM ile; anahtar cihaza bağlı, SoftHSM'de sarılı.
- **4.3 Aktarımdaki veri:** eşlemede TLS 1.3 + sertifika sabitleme; her işlem MAC'li ve sayaçlı (yeniden oynatma yok).
- **4.10 RASP:** hata ayıklayıcı ve kurcalama algılanınca anahtarlar silinir, ödeme reddedilir.
- **4.11 Bellek koruması:** PIN ve anahtar kullanım sonrası güvenli silinir.

Sunucu (localhost benzetimi): Harcanan anahtarları işaretler, sayaç geri sarılmasını reddeder.

Genişletme: İki cihaz arasında doğrudan ödeme; limit aşımında ikinci onay.

02 — Kişisel Parola Kasası

Kısa tanım: Kullanıcının farklı hesaplar için parolalarını tek bir ana parola ile açılan yerel bir kasada sakladığı masaüstü uygulaması. Kasa dosyası çalınabilir ya da cihaza fiziksel erişimi olan biri (aile üyesi, hırsız, kötü amaçlı yazılım) ana parolayı tahmin etmeye ya da bellekte yakalamaya çalışabilir.

Temel özellikler: Kasa oluşturma ve ana parola belirleme · Hesap/parola girişi ekleme-düzenleme · Rastgele güçlü parola üretici · Panoya kopyalama (otomatik temizleme) · Kasa kilitleme/otomatik kilitlenme · Yedekleme

Korunacak varlıklar:

- Ana paroladan türetilen anahtar — **C**
- Kasa içindeki hesap parolaları — **C, I**
- Kasa dosyası bütünlük etiketi — **I+**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** kasa dosyası AES-256-GCM ile şifreli; anahtar Argon2id ile ana paroladan türetilir.
- **4.11 Bellek koruması:** açılan parolalar kullanım sonrası bellekten güvenli silinir; sayfalama dosyasına yazılmaz.
- **4.12 Kriptografi ve sertifikalar:** anahtar türetme parametreleri (tuz, iterasyon) belgeli ve güncel önerilerle uyumlu.
- **4.2 Kullanımdaki veri:** panoya kopyalanan parola belirli bir süre sonra otomatik temizlenir.

Sunucu (localhost benzetimi): Yalnızca şifreli yedek dosyasının senkronize edilmesini benzetir, parolaları çözemez.

Genişletme: İki faktörlü kilit açma (donanım anahtarı benzetimi) ve kasa paylaşımı (aile/takım).

**03 – Tek Kullanımlık Şifre (TOTP) Doğrulayıcı**

Kısa tanım: Kullanıcının hesaplarına ikinci doğrulama katmanı olarak altı haneli, kısa ömürlü kodlar ürettiği bir uygulama. Cihazı ele geçiren ya da tohum (seed) değerini kopyalayan bir saldırgan, kurbanın hesabına ikinci faktör olmadan giriş yapabilir hâle gelir.

Temel özellikler: QR/metin ile hesap ekleme (otpauth) · 30 saniyelik kod üretimi ve geri sayım · Birden çok hesap yönetimi · Yedek kurtarma kodları · Cihaz değişiminde güvenli aktarım · Hesap silme

Korunacak varlıklar:

- TOTP tohum değerleri – C, I+
- Cihaz bağlama anahtarı – C
- Yedek kurtarma kodları – C, I

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** tohum değerleri SQLite'ta şifreli saklanır, anahtar SoftHSM'de sarılı.
- **4.6 Dinamik varlıkların korunması:** tohum yalnız kayıtlı cihazda kullanılabilir; dışa aktarım açıkça uyarılır.
- **4.12 Kriptografi ve sertifikalar:** RFC 6238 uyumlu HMAC-SHA1/256 tabanlı kod üretimi, zaman toleransı belgeli.
- **4.3 Aktarımdaki veri:** hesap kaydı sırasında tohumun aktarımı (varsa) TLS ile korunur.

Sunucu (localhost benzetimi): Hesap kaydında tohum üretimini/ilk eşleşmeyi benzetir; doğrulamayı istemcide tutar.

Genişletme: Push tabanlı onay (evet/hayır) ikinci yöntem olarak eklenir.

**04 – Yazılım Tabanlı POS Benzetimi**

Kısa tanım: Küçük bir işletmenin kart/nakit satış işlemlerini kaydettiği masaüstü satış noktası uygulaması. Kasiyer ya da dışarıdan sızan biri fişleri değiştirmek, günlükleri silmek veya sahte iade oluşturmak isteyebilir.

Temel özellikler: Ürün/sepet yönetimi · Satış tamamlama ve fiş oluşturma · İade işlemi (yetki kontrollü) · Günlük satış özeti · Kasiyer oturumu açma · Sunucuyla senkronizasyon

Korunacak varlıklar:

- İşlem kayıtları ve fişler – **I+**
- Terminal imzalama anahtarı – **C, I+**
- Kasiyer kimlik doğrulama verisi – **C, I**

Öne çıkan gereksinimler:

- **4.7 Varlık yönetimi:** terminal anahtarının kurulumda güvenli enjeksiyonu ve periyodik rotasyonu planlanır.
- **4.3 Aktarımdaki veri:** satış özeti sunucuya gönderimi TLS ve karşılıklı kimlik doğrulama ile yapılır.
- **4.14 Binary uygulama koruması:** yürütülebilir dosya kurcalamaya karşı imzalanır, bütünlüğü başlangıçta doğrulanır.
- **4.13 Sertifikasyon ve sızma testi planı:** sahte iade/fiş değiştirme senaryolarına karşı test planı tanımlanır.

Sunucu (localhost benzetimi): Gün sonu toplamalarını biriktirir; terminal kimliği ve imza doğrulanmadan kayıt kabul etmez.

Genişletme: Çok terminalli mağaza senaryosu; merkezi stok senkronizasyonu.

**05 – Soğuk Kripto Cüzdan Benzetimi**

Kısa tanım: Özel anahtarın hiçbir zaman ağa bağlı bir cihaza çıkmadığı, işlemlerin çevrimdışı imzalanıp bir QR/dosya ile ağa bağlı bileşene taşındığı bir benzetim. Kötü amaçlı yazılım ya da fiziksel erişimi olan biri özel anahtarı sızdırmak ister.

Temel özellikler: Anahtar çifti üretimi ve kurtarma ifadesi gösterimi · Çevrimdışı işlem imzalama · İmzalı işlemi dışa aktarma (QR/dosya) · Bakiye hesaplama (çevrimiçi bileşenden gelen veriyle) · Kurtarma ifadesinden geri yükleme

Korunacak varlıklar:

- Özel anahtar / kurtarma ifadesi – **C, I+**
- İmzalanmış işlemler – **I+**
- Cüzdan dosyası – **C**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** özel anahtar diskte AES-GCM ile şifreli, anahtar SoftHSM'de sarılı olarak tutulur.
- **4.12 Kriptografi ve sertifikalar:** ECDSA/Ed25519 imzalama, kurtarma ifadesi için onaylı entropi kaynağı.
- **4.14 Binary uygulama koruması:** imzalama mantığını içeren kütüphane tersine mühendisliğe karşı sertleştirilir.
- **4.9 Kod sağlama:** anahtar türetme ve imzalama akışındaki kritik semboller gizlenir.

Sunucu (localhost benzetimi): Yalnızca bakiye/işlem geçmişini simüle eden çevrimiçi bileşeni oynar; özel anahtarı asla görmez.

Genişletme: Çoklu imza (m-of-n) onay akışı eklenir.

06 — Sadakat Puanı Cüzdanı

Kısa tanım: Müşterinin alışverişlerden kazandığı puanları biriktirip mağazalarda harcadığı bir cüzdan uygulaması. Kullanıcı yerel bakiyeyi değiştirerek puan üretmeye ya da aynı puanı birden çok mağazada harcamaya çalışabilir.

Temel özellikler: Puan kazanma (fiş tarama/kod girme) · Bakiye görüntüleme · Mağazada puan harcama (QR/kod) · İşlem geçmişi · Kampanya bildirimleri · Sunucuyla senkronizasyon

Korunacak varlıklar:

- Puan bakiyesi — **I+**
- Harcama işlem kodu — **C, I**
- Senkronizasyon oturum anahtarı — **C**

Öne çıkan gereksinimler:

- **4.6 Dinamik varlıkların korunması:** yerel bakiye yalnız gösterim amaçlıdır; gerçek bakiye her seferinde sunucuda doğrulanır.
- **4.8 Arayüz tanımları ve korunması:** puan kazanma/harcama API'si açıkça tanımlanır, imzalı istek zorunlu kılınır.
- **4.3 Aktarımdaki veri:** senkronizasyon TLS 1.3 ile korunur.
- **4.2 Kullanımdaki veri:** harcama anındaki kod kısa ömürlüdür, ekranda sınırlı süre gösterilir.

Sunucu (localhost benzetimi): Gerçek bakiyeyi tutan otoritedir; istemcinin gönderdiği bakiyeye güvenmez, kendi kaydını esas alır.

Genişletme: Mağazalar arası puan transferi ve hediye etme özelliği.

07 – Ön Ödemeli Toplu Taşıma Kartı Benzetimi

Kısa tanım: Bir toplu taşıma kartına yüklenen bakiyenin turnikeden geçişte düşüldüğü, çevrimdışı çalışabilen bir benzetim. Kart/cihaz sahibi bakiyeyi çoğaltmak (klonlamak) ya da geçiş sayacını geri almak isteyebilir.

Temel özellikler: Bakiye yükleme (çevrimiçi olduğunda) · Turnike geçişi benzetimi (bakiye düşme) · İşlem/geçiş geçmiş · Kart durumu sorgulama · Kart engelleme (kayıp/çalıntı) · Sunucuyla mutabakat

Korunacak varlıklar:

- Kart bakiyesi ve geçiş sayacı — **I+** (geri sarılmamalı)
- Yükleme bütünlük kodu (MAC) — **C, I**
- Kart kimliği — **I**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** bakiye ve sayaç yerel depoda şifreli ve MAC'li tutulur.
- **4.6 Dinamik varlıkların korunması:** sayaç yalnızca ileri yönde değişir; geri alma/yeniden oynatma reddedilir.
- **4.12 Kriptografi ve sertifikalar:** yükleme işlemleri simetrik anahtarla MAC'lenir, anahtar karta/cihaza bağlıdır.
- **4.9 Kod sağlamlaştırma:** bakiye güncelleme mantığı klonlamayı zorlaştıracak şekilde sağlamlaştırılır.

Sunucu (localhost benzetimi): Yükleme işlemlerini onaylar ve periyodik mutabakatta kart geçmişini kendi kaydıyla karşılaştırır.

Genişletme: Aile kartı — birden çok kartın tek hesaptan yönetimi.

08 – Masraf Fişi Kasası

Kısa tanım: Çalışanların masraf fişlerini fotoğraflayıp sakladığı, onay sürecine kanıt olarak sunduğu bir uygulama. Kullanıcı ya da araya giren biri fiş görüntüsünü ya da tutarını onaydan sonra değiştirmek isteyebilir.

Temel özellikler: Fiş fotoğrafı ekleme · Tutar/kategori etiketleme · Onaya gönderme · Onay durumu takibi · Fiş arşivi arama · Dışa aktarma (rapor)

Korunacak varlıklar:

- Fiş görüntü dosyaları – C, I+
- Fiş meta verisi (tutar, tarih) – I+
- Onay imzası – I+

Öne çıkan gereksinimler:

- **4.5 Statik varlıkların korunması:** fiş görüntüleri diskte şifreli saklanır, uygulama dışından doğrudan okunamaz.
- **4.12 Kriptografi ve sertifikalar:** her fiş gönderiminde içerik özetlenip imzalanır; sonradan değişiklik tespit edilir.
- **4.7 Varlık yönetimi:** fişlerin saklama süresi ve arşivden silinme politikası tanımlanır.
- **4.13 Sertifikasyon ve sızma testi planı:** fiş sahteciliği/tutar değiştirme senaryoları test planına eklenir.

Sunucu (localhost benzetimi): Onaylanan fişlerin özet/imza kaydını tutar, sonraki fişi bu kayıtlı karşılaştırıp tutarsızlığı işaretler.

Genişletme: Çoklu onaylayıcı (yönetici + muhasebe) iş akışı.

09 – Şifreli Kişisel Bütçe Defteri

Kısa tanım: Kullanıcının gelir-gider kayıtlarını kategorilere ayırarak tuttuğu yerel bir uygulama. Cihaza erişen biri harcama alışkanlıkları gibi hassas kişisel bilgiyi okumak isteyebilir.

Temel özellikler: Gelir/gider kaydı ekleme · Kategori ve bütçe limiti tanımlama · Aylık özet ve grafik · Dışa aktarma (şifreli yedek) · Ana parola ile kilitleme · Çoklu hesap/cüzdan

Korunacak varlıklar:

- Gelir-gider kayıtları – C
- Bütçe limitleri ve kategoriler – I
- Ana paroladan türetilen anahtar – C

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** kayıtlar SQLite'ta AES-GCM ile şifreli tutulur.
- **4.2 Kullanımdaki veri:** kayıtlar yalnızca kilidi açıkken bellekte çözülür, kilitlenince görünürlük kapanır.
- **4.11 Bellek koruması:** ana parola ve türetilen anahtar kullanım sonrası bellekten silinir.
- **4.1 Geliştirme ortamı güvenliği:** test verileri gerçek finansal veri içermez, sentetik veri kullanılır.

Sunucu (localhost benzetimi): Yalnızca isteğe bağlı şifreli yedek dosyasının yüklenmesini benzetir, içeriği çözemez.

Genişletme: Aile üyeleri arasında paylaşımlı, izinlendirilmiş kategoriler.



10 – Hediye Kartı Üretim ve Doğrulama Sistemi



Kısa tanım: Bir mağazanın hediye kartı kodları ürettiği ve kasada bu kodları doğrulayıp bakiye düştüğü bir sistem. Saldırgan geçerli bir kod tahmin etmeye ya da aynı kodu birden çok kez kullanmaya çalışabilir.

Temel özellikler: Kart kodu üretimi (belirli tutarda) · Kod doğrulama ve bakiye sorgulama · Kısmi harcama (kalan bakiye) · Kart iptal etme · İşlem günlüğü · Toplu kart üretimi

Korunacak varlıklar:

- Kart kodları ve ilişkili bakiye – **C, I+**
- Kod imzalama/HMAC anahtarı – **C, I+**
- İşlem günlüğü – **I**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** kart kodları rastgele üretilir ve HMAC ile doğrulanır; kod tahmini imkânsız kılınır.
- **4.8 Arayüz tanımları ve korunması:** doğrulama arayüzü hız sınırlaması ile korunur (kaba kuvvete karşı).
- **4.6 Dinamik varlıkların korunması:** bir kod yalnız bir kez tam harcanabilir; yarış durumu önlenir.
- **4.13 Sertifikasyon ve sızma testi planı:** kod tahmini ve çift harcama senaryolarına karşı test planı hazırlanır.

Sunucu (localhost benzetimi): Kart kodlarının ve kalan bakiyenin tek doğru kaydını tutar, eşzamanlı istekleri sıraya koyar.

Genişletme: Kartın belirli bir mağaza zinciriyle sınırlandırılması (whitelisting).

11 – Mikrokredi Başvuru İstemcisi

Kısa tanım: Kullanıcının küçük tutarlı kredi başvurusu için kişisel ve mali bilgilerini girip gönderdiği bir istemci. Başvuru verisi hem kullanıcı için hassastır hem de araya giren biri tarafından değiştirilip kredi kararını etkileyebilir.

Temel özellikler: Kimlik ve gelir bilgisi formu · Belge ekleme (sentetik gelir belgesi) · Başvuru gönderme · Başvuru durumu sorgulama · Geçmiş başvurular · Bildirim

Korunacak varlıklar:

- Kimlik ve mali bilgiler – C, I
- Başvuru belgeleri – C, I+
- Oturum/istek imzası – I

Öne çıkan gereksinimler:

- **4.2 Kullanımdaki veri:** form doldurulurken hassas alanlar yalnız gerekli süre boyunca bellekte açık tutulur.
- **4.4 Beklemedeki veri:** taslak başvuru yerel diskte şifreli saklanır.
- **4.3 Aktarımdaki veri:** başvuru gönderimi TLS 1.3 ile korunur, sunucu sertifikası doğrulanır.
- **4.15 OWASP ve derleme/dağıtım hattı:** girdiler sunucu tarafında da doğrulanır; enjeksiyon sınıfı açıklar derleme hattında taranır.

Sunucu (localhost benzetimi): Başvuruları alır, sentetik bir puanlama kuralıyla ön değerlendirme yapar; gerçek bir kredi kararı vermez.

Genişletme: Belge doğrulama adımı (sentetik imza kontrolü) eklenir.



12 — \$ Döviz Bürosu Kasa Uygulaması



Kısa tanım: Bir döviz bürosunun güncel kurlarla alım-satım işlemi yaptığı kasa uygulaması. Kasiyer ya da dışarıdan biri kur değerini değiştirerek haksız kazanç sağlamak isteyebilir.

Temel özellikler: Güncel kur listesi görüntüleme · Alım/satım işlemi hesaplama · Kasa bakiyesi (döviz bazında) takibi · İşlem fişi oluşturma · Gün sonu mutabakat · Kur güncelleme (yetkili)

Korunacak varlıklar:

- Kur listesi — I+
- Kasa bakiyeleri — I+
- İşlem kayıtları — I

Öne çıkan gereksinimler:

- **4.6 Dinamik varlıkların korunması:** kur listesi yalnız yetkili kanaldan değişir; işlem sırasında değer tutarlılığı denetlenir.
- **4.7 Varlık yönetimi:** güncel kurun güvenilir kaynaktan periyodik çekilmesi ve önbellek geçerlilik süresi yönetilir.
- **4.12 Kriptografi ve sertifikalar:** kur güncellemesi sunucu tarafından imzalanır, istemci imzayı doğrulamadan uygulamaz.
- **4.9 Kod sağlamlaştırma:** hesaplama mantığı bellek/binary düzeyde değiştirilmeye karşı sağlamlaştırılır.

Sunucu (localhost benzetimi): İmzalı kur listesini yayınlar; kasa uygulamaları yalnız bu imzalı listeyi kabul eder.

Genişletme: Çok şubeli büro senaryosu, merkezi limit kontrolü.

13 – Çocuk Harçlık Cüzdanı



Kısa tanım: Bir ebeveynin çocuğa dijital harçlık tanımlayıp harcama limitini uzaktan yönettiği bir cüzdan. Cihaza fiziksel erişimi olan çocuk, harcama limitini ya da bakiyeyi kendi lehine değiştirmeye çalışabilir.

Temel özellikler: Ebeveyn tarafından bakiye/limit tanımlama · Çocuk tarafında bakiye görüntüleme ve harcama · Harcama kategorisi kısıtlama · İşlem geçmişi (ebeveyne görünür) · Ebeveyn-çocuk cihaz eşleme · Bildirimler

Korunacak varlıklar:

- Bakiye ve harcama limiti – I+
- Ebeveyn-çocuk eşleme anahtarı – C, I
- İşlem geçmişi – I

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** bakiye ve limit çocuğun cihazında şifreli ve bütünlük korumalı tutulur.
- **4.6 Dinamik varlıkların korunması:** limit ve bakiye yalnızca ebeveyn cihazından gelen imzalı komutla değişebilir; yerel düzenleme reddedilir.
- **4.8 Arayüz tanımları ve korunması:** ebeveyn-çocuk eşleme arayüzü karşılıklı kimlik doğrulama gerektirir.
- **4.9 Kod sağlamlaştırma:** bakiye/limit kontrol mantığı yerel değiştirmeye karşı sağlamlaştırılır.

Sunucu (localhost benzetimi): Ebeveyn-çocuk eşlemesini ve komut imzalarını doğrular, bakiye değişikliklerini merkezi kaydeder.

Genişletme: Birden çok çocuk/hesap için tek ebeveyn panosu.



14 — Kapalı Zarf Açık Artırma İstemcisi



Kısa tanım: Katılımcıların tekliflerini herkesten (sunucu dâhil) gizli tutup yalnızca belirlenen açılış anında ortaya çıkardığı bir açık artırma istemcisi. Erken açıklanan ya da değiştirilebilen bir teklif haksız avantaj sağlar.

Temel özellikler: Teklif oluşturma ve gönderme (taahhüt) · Teklif geçmişi (kendi) · Açılış anında teklifi açma (reveal) · Kazananın belirlenmesi · İhale durumu görüntüleme

Korunacak varlıklar:

- Teklif tutarı (açılışa kadar) — **C**
- Taahhüt (commitment) değeri — **I+**
- Açma (reveal) anahtarı/tuzu — **C, I**

Öne çıkan gereksinimler:

- **4.2 Kullanımdaki veri:** teklif tutarı yalnız gönderim anında bellekte oluşturulur, ekranda gereksiz yere tutulmaz.
- **4.12 Kriptografi ve sertifikalar:** teklif önce bir taahhüt (hash-commit) olarak gönderilir, açılışta tuz ile doğrulanır.
- **4.3 Aktarımdaki veri:** taahhüt ve açma verisi TLS ile korunur.
- **4.13 Sertifikasyon ve sızma testi planı:** erken teklif sızıntısı ve taahhüt sonrası değiştirme senaryoları test edilir.

Sunucu (localhost benzetimi): Taahhütleri toplar, açılış anına kadar çözemez; açılış sonrası tüm teklifleri karşılaştırıp kazananı ilan eder.

Genişletme: Minimum artış payı ve son anda teklif geldiğinde otomatik süre uzatma kuralı.



15 – E-Fiş İmzalayıcı



Kısa tanım: Bir satış noktasının kestiği elektronik fişi dijital olarak imzalayıp müşteriye doğrulanabilir kanıt sunan bir bileşen. Saldırgan sahte bir fiş üretip gerçekmiş gibi göstermek isteyebilir.

Temel özellikler: Fiş içeriği oluşturma · Dijital imzalama · İmza doğrulama (müşteri/denetçi tarafı) · İmzalı fiş arşivi · QR ile doğrulama bağlantısı · Anahtar/sertifika görüntüleme

Korunacak varlıklar:

- İmzalama özel anahtarı – C, I+
- İmzalı fiş kayıtları – I+
- Sertifika zinciri – I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** RSA/ECDSA ile imzalama, sertifika zinciri ve süre kontrolü uygulanır.
- **4.7 Varlık yönetimi:** imzalama anahtarının üretimi, saklanması ve süresi dolduğunda yenilenmesi planlanır.
- **4.4 Beklemedeki veri:** özel anahtar [SoftHSM/PKCS#11](#) aracılığıyla sarılı tutulur, uygulama anahtarı göremez.
- **4.14 Binary uygulama koruması:** imzalama çağrısını yapan binary, anahtarı doğrudan dışa aktaramayacak şekilde korunur.

Sunucu (localhost benzetimi): İmzalı fişlerin özetini saklar, QR ile gelen doğrulama isteğinde fişin gerçekliğini teyit eder.

Genişletme: Toplu fiş imzalama ve zaman damgası (timestamp) entegrasyonu.

16 — Sigorta Hasar Başvuru İstemcisi



Kısa tanım: Bir sigortalının hasar fotoğrafı ve açıklamasıyla başvuru oluşturduğu istemci. Başvuru sahibi ya da araya giren biri, hasar fotoğrafını ya da tutarını başvuru sonrası değiştirip haksız ödeme almaya çalışabilir.

Temel özellikler: Hasar açıklaması ve fotoğraf ekleme · Poliçe bilgisi girme (sentetik) · Başvuru gönderme · Durum takibi · Ek belge yükleme · Bildirim

Korunacak varlıklar:

- Hasar fotoğrafları ve açıklaması — **C, I+**
- Poliçe/kimlik bilgisi — **C**
- Başvuru bütünlük özeti — **I+**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** başvuru taslağı ve fotoğraflar yerelde şifreli tutulur.
- **4.5 Statik varlıkların korunması:** fotoğraf dosyaları uygulama dışından erişilemeyecek şekilde korunur.
- **4.12 Kriptografi ve sertifikalar:** gönderim anında içerik özetlenir; sonraki her erişimde özet karşılaştırılarak değişiklik tespit edilir.
- **4.15 OWASP ve derleme/dağıtım hattı:** dosya yükleme yolu, tür/uzunluk doğrulaması ile yaygın yükleme açıklarına karşı sağlamlştırılır.

Sunucu (localhost benzetimi): Gönderilen özetle başvuru bütünlüğünü korur; sonraki "güncelleme" istekleri yeni bir kayıt olarak işlenir.

Genişletme: İki bağımsız değerlendiricinin (benzetim) çapraz onayı.

**17 – İmzalı Makbuzlu Bağış Takibi**

Kısa tanım: Bir bağışçının yaptığı bağışların dijital imzalı makbuzlarla kayıt altına alındığı bir takip uygulaması. Kötü niyetli biri sahte makbuz üretmek ya da bir makbuzu birden çok kez kullanmak isteyebilir.

Temel özellikler: Bağış kaydı oluşturma · Makbuz üretimi ve imzalama · Makbuz doğrulama · Yıllık bağış özeti · Bağış geçmişini arama · Dışa aktarma (rapor)

Korunacak varlıklar:

- Makbuz imzalama anahtarı – **C, I+**
- Makbuz kayıtları – **I+**
- Bağışçı bilgisi (sentetik) – **C**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** her makbuz benzersiz bir seri numarasıyla imzalanır.
- **4.6 Dinamik varlıkların korunması:** bir makbuz numarasının yeniden kullanımı (aynı makbuzu iki kez ibraz etme) reddedilir.
- **4.7 Varlık yönetimi:** makbuz arşivinin uzun süreli saklanması ve erişim yetkilendirmesi planlanır.
- **4.13 Sertifikasyon ve sızma testi planı:** makbuz sahteciliği ve tekrar kullanım senaryolarına yönelik test planı tanımlanır.

Sunucu (localhost benzetimi): Yayımlanan her makbuz numarasını ve durumunu tutar; doğrulamada numaranın daha önce kullanılıp kullanılmadığını kontrol eder.

Genişletme: Kurumsal bağışlar için toplu makbuz oluşturma.

18 – 📅 Şifreli Abonelik ve Ödeme Hatırlatıcı

Kısa tanım: Kullanıcının abonelik ödemelerini ve son dört haneli maskeli kart bilgilerini takip ederek hatırlatma gönderen bir uygulama. Cihaza erişen biri maskeli de olsa ödeme alışkanlıkları ve abonelik verilerini görmek isteyebilir.

Temel özellikler: Abonelik ekleme (ad, tutar, tarih) · Maskeli ödeme yöntemi kaydı · Yaklaşan ödeme hatırlatması · Aylık toplam özeti · Abonelik iptali işaretleme · Şifreli yedekleme

Korunacak varlıklar:

- Abonelik ve tutar kayıtları — **C**
- Maskeli ödeme meta verisi — **C**
- Ana paroladan türetilen anahtar — **C**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** tüm kayıtlar SQLite'ta AES-GCM ile şifreli tutulur.
- **4.2 Kullanımdaki veri:** kart bilgisi yalnızca son dört hane gösterilecek şekilde işlenir, tam numara hiç tutulmaz.
- **4.1 Geliştirme ortamı güvenliği:** geliştirme ve test sırasında yalnız sentetik veri kullanılır, gerçek veri kod tabanına girmez.
- **4.11 Bellek koruması:** kilidi açan ana parola kullanım sonrası bellekten temizlenir.

Sunucu (localhost benzetimi): Yalnızca isteğe bağlı şifreli yedeğin alınmasını benzetir.

Genişletme: Aile üyeleri arasında paylaşımlı abonelik takibi.

19 — Gün Sonu Kasa (Z) Raporlayıcı

Kısa tanım: Bir kasiyerin gün sonunda kasayı kapatıp değiştiremez bir "Z raporu" ürettiği uygulama. Kasiyer ya da yönetici, kapanış sonrası raporu kendi lehine değiştirmek isteyebilir.

Temel özellikler: Gün içi satış toplamalarını görüntüleme · Kasa sayımı girişi · Z raporu oluşturma (kapanış) · Rapor arşivi ve arama · Fark (kasa açığı/fazlası) hesaplama · Rapor dışı aktarma

Korunacak varlıklar:

- Z raporu (kapanış sonrası) — **I+**
- Kasa sayım verisi — **I**
- Rapor imzalama anahtarı — **C, I+**

Öne çıkan gereksinimler:

- **4.6 Dinamik varlıkların korunması:** bir Z raporu kapatıldıktan sonra hiçbir alanı düzenlenemez; düzeltme yalnız yeni kayıtla yapılır.
- **4.12 Kriptografi ve sertifikalar:** kapanışta rapor özetlenip imzalanır; imza raporla birlikte saklanır.
- **4.9 Kod sağlamlaştırma:** kapanış ve imzalama akışı, uygulama belleğinde doğrudan düzenlemeye karşı sağlamlaştırılır.
- **4.13 Sertifikasyon ve sızma testi planı:** kapanmış raporu değiştirme girişimlerine karşı test senaryoları tanımlanır.

Sunucu (localhost benzetimi): Kapanan her Z raporunun imzalı özetini saklar; aynı gün için ikinci bir kapanışı reddeder.

Genişletme: Vardiya bazlı ara raporlar (X raporu) eklenir.

20 — Kurumsal Harcama Kartı Limit Yöneticisi



Kısa tanım: Bir şirketin çalışanlarına tanımladığı sanal harcama kartlarının limitini yönettiği uygulama. Çalışan, kendi kartının limitini ya da kategorisini yetkisiz şekilde yükseltmeye çalışabilir.

Temel özellikler: Kart tanımlama (limit, kategori) · Harcama isteği oluşturma · Onay iş akışı (yönetici) · Harcama geçmişi · Limit/kategori güncelleme (yetkili) · Kart askıya alma

Korunacak varlıklar:

- Kart limiti ve kategori kuralları — **I+**
- Maskeli kart meta verisi — **C**
- Onay yetkisi/rolü — **I**

Öne çıkan gereksinimler:

- **4.8 Arayüz tanımları ve korunması:** limit güncelleme arayüzü yalnız yönetici rolüne açıktır, rol sunucu tarafında doğrulanır.
- **4.6 Dinamik varlıkların korunması:** çalışan istemcisi kendi limitini yerel değiştiremez; her istek sunucudaki güncel limite göre onaylanır.
- **4.4 Beklemedeki veri:** kart ve limit verisi yerelde şifreli önbelleğe alınır.
- **4.15 OWASP ve derleme/dağıtım hattı:** rol/yetki kontrolleri her uç noktada tutarlı uygulanır (yetki yükseltmeye karşı).

Sunucu (localhost benzetimi): Güncel limit ve rollerin tek doğru kaynağıdır; istemciden gelen limit bilgisine asla güvenmez.

Genişletme: Kategori bazlı otomatik onay eşiği (küçük tutarlar için onaysız geçiş).



21 – ATM İstemci Benzetimi



Kısa tanım: Bir ATM'nin kart okuma, PIN girme ve para çekme adımlarını benzeten masaüstü uygulaması. Fiziksel erişimi olan bir saldırgan PIN'i yakalamaya, işlemi tekrarlatmaya (replay) ya da yazılımı hackleyip fazladan para çekirmeye (jackpotting benzetimi) çalışabilir.

Temel özellikler: Kart takma benzetimi · PIN girişi (güvenli tuş takımı) · Bakiye sorgulama · Para çekme (limit kontrollü) · İşlem makbuzu · Ana bilgisayarla (host) iletişim

Korunacak varlıklar:

- PIN ve PIN blok verisi – C, I+
- İşlem oturum anahtarı – C
- Para çekme işlem sayacı – I+

Öne çıkan gereksinimler:

- **4.14 Binary uygulama koruması:** ATM yazılımı, yetkisiz DLL enjeksiyonu ve sürece kanca takmaya (hooking) karşı korunur.
- **4.3 Aktarımdaki veri:** PIN bloğu ve işlem isteği host'a şifreli ve MAC'li gönderilir.
- **4.10 RASP:** hata ayıklayıcı bağlama veya bellek dökümü girişimi algılanınca işlem iptal edilir ve oturum sonlandırılır.
- **4.12 Kriptografi ve sertifikalar:** PIN blok şifreleme düzenine uygun anahtar yönetimi uygulanır.

Sunucu (localhost benzetimi): Host bileşeni bakiye ve günlük çekim limitini tutar; her işlemi imza/MAC doğrulamadan onaylamaz.

Genişletme: Kartsız (QR/kod ile) para çekme senaryosu.



22 – QR ile Ödeme İstemcisi



Kısa tanım: Kullanıcının bir QR kod üretip/tarayıp ödeme yaptığı bir istemci. Saldırgan bir QR kodu kaydedip daha sonra tekrar kullanmaya (replay) ya da süresi dolmuş bir kodu yeniden canlandırmaya çalışabilir.

Temel özellikler: Ödeme talebi için QR üretme · QR tarayarak ödeme yapma · İşlem onayı ve makbuz · İşlem geçmişi · Bakiye görüntüleme · QR geçerlilik süresi gösterimi

Korunacak varlıklar:

- QR ödeme yükü (tutar, alıcı, zaman damgası) – **I+**
- İmza/MAC anahtarı – **C, I+**
- İşlem geçmişi – **I**

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** QR içeriği ve ödeme onayı TLS üzerinden sunucuya iletilir.
- **4.12 Kriptografi ve sertifikalar:** QR yükü zaman damgalı olarak imzalanır; imza olmadan işlem kabul edilmez.
- **4.6 Dinamik varlıkların korunması:** her QR yalnız bir kez ve süresi içinde kullanılabilir; kullanılmış/süresi geçmiş kod reddedilir.
- **4.8 Arayüz tanımları ve korunması:** QR yük biçimi (alan sırası, sürüm) net tanımlanır ve doğrulanmadan ayrıştırılmaz.

Sunucu (localhost benzetimi): Her QR kodunu bir kez kullanılabilir olarak işaretler ve tekrar geldiğinde reddeder.

Genişletme: Statik (sabit) QR ile dinamik tutarlı bağış/ödeme kutusu senaryosu.

23 — Esnaf Veresiye Defteri



Kısa tanım: Bir esnafın müşterilerine açtığı veresiye (borç) hesaplarını tuttuğu bir defter uygulaması. Esnaf ya da yardımcı çalışan geçmiş borç kayıtlarını fark ettirmeden değiştirmek isteyebilir.

Temel özellikler: Müşteri hesabı açma · Borç/ödeme kaydı ekleme · Bakiye görüntüleme (müşteri bazlı) · Geçmiş kayıt arama · Aylık özet · Yedekleme

Korunacak varlıklar:

- Müşteri borç/ödeme kayıtları — **I+**
- Esnaf kimlik doğrulama verisi — **C, I**
- Yedek dosyası — **C, I**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** kayıtlar SQLite'ta şifreli ve bütünlük korumalı tutulur.
- **4.6 Dinamik varlıkların korunması:** geçmiş bir kayıt silinemez/üzerine yazılamaz; düzeltme yalnız yeni bir ters kayıtla yapılır.
- **4.7 Varlık yönetimi:** düzenli şifreli yedekleme ve saklama süresi politikası tanımlanır.
- **4.1 Geliştirme ortamı güvenliği:** geliştirme ortamında gerçek müşteri verisi kullanılmaz, sentetik isim/tutarlarla test edilir.

Sunucu (localhost benzetimi): Yalnızca şifreli yedeğin periyodik gönderimini benzetir.

Genişletme: Müşteriye borç hatırlatma bildirimi (yerel bildirim benzetimi).

**24 – Vergi Beyanı Hazırlama Yardımcısı**

Kısa tanım: Kullanıcının gelir kalemlerini girip vergi beyanı taslağı hesapladığı bir yardımcı uygulama. Girilen mali veriler son derece hassastır; araya giren biri hem veriyi okumak hem de hesap sonucunu değiştirmek isteyebilir.

Temel özellikler: Gelir kalemi girişi (sentetik) · İstisna/indirim seçimi · Otomatik vergi hesaplama · Taslak beyanname önizleme · Geçmiş yıl karşılaştırma · Dışa aktarma (PDF benzetimi)

Korunacak varlıklar:

- Gelir ve mali veri girdileri – **C**
- Hesaplama sonucu/taslak beyanname – **C, I**
- Ana paroladan türetilen anahtar – **C**

Öne çıkan gereksinimler:

- **4.2 Kullanımdaki veri:** hesaplama yalnız bellekte yapılır, ara sonuçlar diske düz metin olarak yazılmaz.
- **4.4 Beklemedeki veri:** taslak beyanname yerelde şifreli saklanır.
- **4.15 OWASP ve derleme/dağıtım hattı:** girdi doğrulama (aşırı/negatif değerler, enjeksiyon) derleme hattında statik analizle desteklenir.
- **4.13 Sertifikasyon ve sızma testi planı:** hesaplama mantığının hatalı/kötü niyetli girdilerle test edilmesi planlanır.

Sunucu (localhost benzetimi): Yalnız güncel vergi dilimi/oranlarının (sentetik) çekilmesini benzetir; kullanıcı verisini işlemez.

Genişletme: Serbest meslek/kira geliri gibi ek gelir türleri desteği.



25 – Tapu ve Emlak Belge Kasası



Kısa tanım: Bir kullanıcının tapu senedi ve emlak belgelerini dijital olarak sakladığı ve gerektiğinde doğrulanabilir şekilde paylaştığı bir kasa uygulaması. Saldırgan belge içeriğini değiştirip sahte mülkiyet iddiasında bulunmak isteyebilir.

Temel özellikler: Belge tarama/ekleme · Belge kategorileme (tapu, ruhsat, sigorta) · Noter/kurum imzası doğrulama (benzetim) · Belge paylaşma (doğrulama bağlantısı) · Sürüm/geçmiş görüntüleme · Şifreli arşivleme

Korunacak varlıklar:

- Belge dosyaları – C, I+
- Noter/kurum imza sertifika zinciri – I+
- Kasa şifreleme anahtarı – C

Öne çıkan gereksinimler:

- **4.5 Statik varlıkların korunması:** belge dosyaları diskte şifreli tutulur ve uygulama dışından doğrudan erişilemez.
- **4.12 Kriptografi ve sertifikalar:** her belgenin imza zinciri doğrulanır; kök sertifika (benzetim) uygulamaya gömülü ve değiştirilemez tutulur.
- **4.7 Varlık yönetimi:** belge sürümlerinin uzun süreli arşivlenmesi ve erişim yetkilendirmesi planlanır.
- **4.14 Binary uygulama koruması:** imza doğrulama mantığını içeren kütüphane, doğrulamayı atlatacak yamalanmaya karşı korunur.

Sunucu (localhost benzetimi): Paylaşım bağlantısıyla gelen doğrulama isteklerinde belgenin özet/imza kaydını karşılaştırır.

Genişletme: Çoklu mülk sahipliği (hisseli tapu) senaryosunda çok taraflı onay.



26 – Kişisel Sağlık Kaydı Kasası



Kısa tanım: Kullanıcının sentetik tanı, ilaç ve alerji kayıtlarını yerel bir kasada tuttuğu uygulama. Saldırgan cihazı ele geçiren ya da kaybolan bir cihazı bulan kişidir; kayıtları okumak veya sessizce değiştirmek ister.

Temel özellikler: Kayıt ekleme/düzenleme · Kategoriye göre görüntüleme (tanı/ilaç/alerji) · Acil durum özet kartı · Şifreli dışa aktarma · Erişim günlüğü · Sunucuyla senkronizasyon

Korunacak varlıklar:

- Sağlık kayıtları (sentetik) – C, I
- Acil durum özet kartı – I
- Erişim günlüğü – I+
- Kasa şifreleme anahtarı – C

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** kayıtlar SQLite'ta AES-GCM ile; anahtar SoftHSM'de sarılı tutulur.
- **4.2 Kullanımdaki veri:** kayıt açık metni yalnız görüntülenirken bellekte tutulur, süresi kısıtlıdır.
- **4.7 Varlık yönetimi:** kasa anahtarının periyodik rotasyonu ve eski anahtarla şifrelenmiş verinin yeniden şifrelenmesi.
- **4.11 Bellek koruması:** görüntülenen kayıt kapatılınca bellekten güvenli silinir.

Sunucu (localhost benzetimi): Senkronize edilen kayıtları saklar, çakışan sürümleri sürüm numarasıyla çözer.

Genişletme: Aile üyeleri için rol bazlı, kısmi paylaşımlı erişim.

27 – E-Reçete Doğrulayıcı



Kısa tanım: Eczacının hekim tarafından imzalanmış sentetik reçeteyi okuyup imzasını ve kullanım durumunu doğruladığı uygulama. Saldırgan sahte reçete üretmek ya da geçerli bir reçeteyi birden fazla kez kullanmak isteyen kişidir.

Temel özellikler: Reçete tarama (QR/kod) · İmza doğrulama · İlaç ve doz görüntüleme · Kullanım işaretleme (tek kullanım) · Doğrulama geçmişi · Sunucudan kullanım kontrolü

Korunacak varlıklar:

- Reçete imzası – I+
- Hekim sertifikası / genel anahtarı – I
- Kullanım durumu bayrağı – I+ (tekrar kullanılmamalı)
- Hasta bilgisi (sentetik) – C

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** OpenSSL ile imza doğrulama, hekim sertifika zincirinin kontrolü.
- **4.3 Aktarımdaki veri:** kullanım kontrolü için sunucuyla TLS 1.3 üzerinden iletişim.
- **4.9 Kod sağlamlaştırma:** imza doğrulama adımının atlatılmasına karşı kontrol akışı sağlamlaştırması.
- **4.13 Sertifikasyon ve sızma testi planı:** sahte reçete/tekrar kullanım senaryolarını kapsayan test planı.

Sunucu (localhost benzetimi): Reçete numarasının daha önce kullanılıp kullanılmadığını kontrol eder.

Genişletme: Birden fazla eczane arasında kullanım durumunun senkronizasyonu.

28 – İlaç Hatırlatıcı ve Doz Kaydı

Kısa tanım: Kişisel ilaç programını ve alınan dozları kaydeden uygulama. Saldırgan doz kayıtlarını değiştirerek yanlış bir tedavi geçmişini gösterebilecek kişidir (kullanıcının kendisi ya da cihaza erişen biri).

Temel özellikler: İlaç programı oluşturma · Hatırlatma · Doz alındı işaretleme · Geçmiş görüntüleme · Rapor dışı aktarma · Sunucuyla yedekleme

Korunacak varlıklar:

- Doz kayıtları – **I+**
- İlaç programı – **I**
- Dışa aktarılan rapor – **C, I**
- Yedekleme anahtarı – **C**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** doz kayıtları SQLite'ta şifreli; anahtar SoftHSM'de saklanır.
- **4.6 Dinamik varlıkların korunması:** çalışma zamanında doz kaydı listesinin bütünlük kontrolü.
- **4.8 Arayüz tanımları ve korunması:** kayıt güvenlik kütüphanesinin (DLL/.so) arayüzünde girdi doğrulama.
- **4.10 RASP:** hata ayıklayıcı bağlanması algılanınca kayıt değişikliği kilitlenir.

Sunucu (localhost benzetimi): Yedekleri saklar, sayaç/sürüm numarasının geri sarılmasını reddeder.

Genişletme: Bakıcı/aile üyesine doz kaçırmaya bildirimi.



29 – Hasta Onam Formu İmzalayıcı



Kısa tanım: Bir işlem öncesi sentetik hasta onam formunun dijital olarak imzalandığı uygulama. Saldırgan imzasız ya da sonradan değiştirilmiş bir formu geçerliymiş gibi göstermek isteyen kişidir.

Temel özellikler: Form görüntüleme · Dijital imza yakalama · Zaman damgalama · İmzalı belge üretimi · Doğrulama · Arşivleme

Korunacak varlıklar:

- İmza özel anahtarı – C
- İmzalanmış form özeti – I+
- Zaman damgası – I
- Hasta kimliği (sentetik) – C

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** OpenSSL ile imzalama ve zaman damgası ekleme.
- **4.5 Statik varlıkların korunması:** form şablonunun bütünlüğü, değiştirilmiş şablonla imzalama engellenir.
- **4.14 Binary uygulama koruması:** imzalama fonksiyonunun tersine mühendisliğe karşı korunması.
- **4.9 Kod sağlama:** imza adımını atlatmaya yönelik hata ayıklama/patch denemelerine karşı sağlama.

Sunucu (localhost benzetimi): İmzalanmış formları arşivler, zaman damgası otoritesi rolünü benzetir.

Genişletme: Hekim ve hasta olmak üzere çok taraflı imza akışı.

30 – Laboratuvar Sonucu İletim İstemcisi

Kısa tanım: Sentetik laboratuvar sonuçlarının hastaya veya hekime uçtan uca güvenli iletildiği uygulama. Saldırgan sonuçları değiştirmek ya da yetkisiz biri olarak görmek isteyen kişidir.

Temel özellikler: Sonuç alma · Şifre çözme ve görüntüleme · Referans aralığıyla karşılaştırma · Bildirim · PDF dışı aktarma · Sunucudan çekme

Korunacak varlıklar:

- Laboratuvar sonucu (sentetik) – C, I+
- Hasta-sonuç eşleşme anahtarı – C
- İletim kaydı – I

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** uçtan uca şifreleme; sonucu yalnız şifreli veriyi taşır, içeriği göremez.
- **4.4 Beklemedeki veri:** cihazda alınan sonuç SQLite'ta şifreli saklanır.
- **4.7 Varlık yönetimi:** sonucu çözecek anahtarın hasta cihazına güvenli teslimi.
- **4.2 Kullanımdaki veri:** sonuç yalnız görüntülenirken çözülür, ekrandan çıkınca bellekten silinir.

Sunucu (localhost benzetimi): Yalnız şifreli veriyi saklar/iletir, içeriği çözemez.

Genişletme: Sonucun birden fazla hekimle paylaşılması ve geri çağırılması (revoke).

31 – Klinik Randevu İstemcisi

Kısa tanım: Hasta ve hekim arasında randevu alma iptal işlemlerini yürüten uygulama. Saldırgan başkası adına randevu değiştirmek ya da randevu listesini yetkisiz görmek isteyen kişidir.

Temel özellikler: Randevu arama · Randevu alma iptal · Hatırlatma · PIN ile kimlik doğrulama · Randevu geçmişi · Sunucu senkronizasyonu

Korunacak varlıklar:

- Randevu kaydı – I
- Kimlik doğrulama verisi (PIN özeti) – C, I
- Oturum belirteci – C

Öne çıkan gereksinimler:

- **4.2 Kullanımdaki veri:** PIN doğrulaması sırasında açık değer bellekte kalış süresi kısıtlanır.
- **4.3 Aktarımdaki veri:** sunucuyla iletişim TLS 1.3 ve sertifika sabitleme (pinning) ile korunur.
- **4.8 Arayüz tanımları ve korunması:** randevu güvenlik kütüphanesinin dışı açık arayüzü minimal ve doğrulamalı tutulur.
- **4.15 OWASP ve derleme/dağıtım hattı:** girdi doğrulama ve derleme hattında statik analiz.

Sunucu (localhost benzetimi): Randevu çakışmalarını localhost üzerinde çözer.

Genişletme: Bekleme listesi ve çoklu klinik şubesi desteği.



32 – Aşı Kartı Doğrulayıcı



Kısa tanım: Sentetik aşı kayıtlarının imzalı bir QR koduyla doğrulandığı uygulama. Saldırgan sahte aşı kaydı üretmek ya da mevcut bir kaydı değiştirmek isteyen kişidir.

Temel özellikler: QR tarama · İmza doğrulama · Aşı geçmişi görüntüleme · Yetkili kullanıcı için kart üretimi · Doğrulama geçmişi · İptal kontrolü

Korunacak varlıklar:

- Aşı kaydı imzası – I+
- Otorite imza anahtarı – C, I+
- İptal listesi – I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** OpenSSL ile imzalama/doğrulama, otorite sertifika zinciri.
- **4.9 Kod sağlamlaştırma:** QR içeriğinin sahtesini üretme/değiştirme denemelerine karşı sağlamlaştırma.
- **4.13 Sertifikasyon ve sızma testi planı:** sahte kart senaryolarını kapsayan test planı.
- **4.5 Statik varlıkların korunması:** otorite kök sertifikasının uygulama içinde değiştirilmez tutulması.

Sunucu (localhost benzetimi): İptal edilen kayıtları yayınlar (iptal listesi benzetimi).

Genişletme: Çok dozlu aşı takvimi ve sınır geçişi senaryosu benzetimi.

33 – Çevrimdışı Sınav İstemcisi

Kısa tanım: İnternet bağlantısı olmadan sınav çözülen uygulama. Saldırgan sınavı çözen öğrencinin kendisidir; cevapları sonradan değiştirmek, ek süre kazanmak ya da soruları önceden görmek ister.

Temel özellikler: Şifreli sınav indirme · Soru görüntüleme · Cevap kaydetme · Süre takibi · Sonuç gönderme · Kurcalama tespiti

Korunacak varlıklar:

- Soru bankası – C
- Öğrenci cevapları – I+
- Sınav süresi/sayacı – I+ (geri sarılmamalı)
- Sonuç dosyası – I+

Öne çıkan gereksinimler:

- **4.10 RASP:** hata ayıklayıcı bağlanması veya sistem saatinin geri alınması algılanınca sınav sonlandırılır.
- **4.4 Beklemedeki veri:** sorular ve cevaplar SQLite'ta AES-GCM ile şifrelenir.
- **4.11 Bellek koruması:** görüntülenen soru ve cevaplar bellekte yalnız gerekli süre boyunca tutulur.
- **4.6 Dinamik varlıkların korunması:** süre sayacının çalışma zamanında geri sarılmaya karşı korunması.

Sunucu (localhost benzetimi): Bağlantı kurulunca sonuçları toplar, sayaç tutarlılığını denetler.

Genişletme: Çoktan seçmeli ve açık uçlu soruların karışık, rastgele sıralı sunulması.

34 – Sınav Soru Bankası Kasası



Kısa tanım: Öğretim üyesinin soru bankasını şifreli sakladığı ve rastgele sınav kağıdı ürettiği araç. Saldırgan sınava girecek bir öğrenci ya da içeriden biridir; soruları sınavdan önce görmek ister.

Temel özellikler: Soru ekleme/düzenleme · Kategori ve zorluk etiketleme · Rastgele sınav kağıdı üretimi · Şifreli dışa aktarma · Parola ile erişim kontrolü · Sürüm geçmişi

Korunacak varlıklar:

- Soru bankası – C, I
- Yazar kimlik bilgisi – C
- Üretilen sınav kağıdı – C (yayınlanana kadar)

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** soru bankası SQLite'ta şifreli, anahtar SoftHSM'de sarılı.
- **4.5 Statik varlıkların korunması:** uygulamayla birlikte dağıtılan örnek/şablon sorular değiştirilemez tutulur.
- **4.1 Geliştirme ortamı güvenliği:** geliştirme sırasında gerçek soru içeriğinin depoya/derleme çıktısına sızması.
- **4.7 Varlık yönetimi:** soru bankası anahtarının yaşam döngüsü ve erişim yetkisi yönetimi.

Sunucu (localhost benzetimi): Yalnız şifreli yedekleme sağlar; sorular sunucuda hiçbir zaman açık saklanmaz.

Genişletme: Birden fazla öğretim üyesinin izin bazlı paylaştığı ortak soru havuzu.

35 – Öğretim Üyesi Not Defteri



Kısa tanım: Sentetik öğrenci notlarının tutulduğu, bütünlüğü kritik olan bir uygulama. Saldırgan notunu değiştirmek isteyen bir öğrenci ya da not dosyasına erişebilen biridir.

Temel özellikler: Not girişi · Ağırlıklı ortalama hesaplama · Öğrenci bazlı rapor · Not değişikliği günlüğü · Şifreli dışa aktarma · Sunucuyla yedekleme

Korunacak varlıklar:

- Not kayıtları – I+
- Değişiklik günlüğü – I+
- Öğretim üyesi kimlik bilgisi – C

Öne çıkan gereksinimler:

- **4.11 Bellek koruması:** hesaplama sırasında bellekteki not değerlerinin dışarıdan yama/enjeksiyona karşı korunması.
- **4.6 Dinamik varlıkların korunması:** çalışma zamanında not listesinin bütünlük denetimi (checksum).
- **4.9 Kod sağlamlaştırma:** bellek yamalama araçlarıyla not değiştirme denemelerine karşı sağlamlaştırma.
- **4.4 Beklemedeki veri:** not defteri SQLite'ta şifreli, değişiklik günlüğü ayrı imzalanır.

Sunucu (localhost benzetimi): İmzalı yedekleri saklar, geri alma (rollback) denemelerini tespit eder.

Genişletme: Not itiraz sürecinin gerekçeli günlüğe kaydedilmesi.

**36 — Diploma ve Sertifika Doğrulayıcı**

Kısa tanım: Sentetik diploma/sertifikaların dijital imzayla doğrulandığı uygulama. Saldırgan sahte diploma üretmek ya da gerçek bir diplomanın içeriğini değiştirmek isteyen kişidir.

Temel özellikler: Belge yükleme/tarama · İmza doğrulama · Kurum sertifika zinciri kontrolü · Doğrulama sonucu görüntüleme · Geçmiş kayıt · İptal kontrolü

Korunacak varlıklar:

- Kurum imza anahtarı — C, I+
- Diploma verisi — I
- İptal listesi — I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** OpenSSL ile sertifika zinciri doğrulama.
- **4.8 Arayüz tanımları ve korunması:** doğrulama kütüphanesinin (DLL/.so) girdi/çıkış arayüzünün sıkı tanımlanması.
- **4.13 Sertifikasyon ve sızma testi planı:** sahte belge ve zincir manipülasyonu senaryolarını kapsayan test planı.
- **4.15 OWASP ve derleme/dağıtım hattı:** bağımlılık taraması ve imzalı derleme çıktısı.

Sunucu (localhost benzetimi): İptal listesini ve kök sertifikayı yayınlar.

Genişletme: Birden fazla kurum arasında federe güven ağı.

37 – Lisanslı E-Kitap Ödünç Sistemi

Kısa tanım: Dijital kütüphaneden süreli e-kitap ödünç alınan uygulama. Saldırgan okuyucunun kendisidir; ödünç süresini aşmak ya da kitap içeriğini kopyalamak ister.

Temel özellikler: Kitap arama · Süreli ödünç alma · Çevrimdışı okuma · Süre dolunca kilitleme · İade · Sunucuyla lisans kontrolü

Korunacak varlıklar:

- Kitap içerik anahtarı – **C**
- Ödünç süresi/sayacı – **I+** (geri sarılmamalı)
- Kullanıcı lisans belirteci – **C, I**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** kitap içeriği AES-GCM ile şifreli; anahtar SoftHSM'de saklı.
- **4.14 Binary uygulama koruması:** okuyucu uygulamanın tersine mühendislikle içerik anahtarını sızdırmasının engellenmesi.
- **4.10 RASP:** hata ayıklayıcı algılanınca içerik anahtarı bellekten silinir.
- **4.6 Dinamik varlıkların korunması:** ödünç süresi sayacının sistem saati geri alınarak atlatılmasının engellenmesi.

Sunucu (localhost benzetimi): Eş zamanlı ödünç sayısını sınırlar, süre uzatma denemesini reddeder.

Genişletme: Bekleme listesi ve birden fazla cihaz arasında senkronizasyon.



38 – İmzalı QR Yoklama Sistemi



Kısa tanım: Derste imzalı, kısa ömürlü QR kodlarıyla yoklama alınan uygulama. Saldırgan derse gelmeyen bir öğrencidir; arkadaşının QR'ını veya cihazını kullanarak yoklamaya girmek ister.

Temel özellikler: Zaman damgalı QR üretimi · QR tarama · Cihaz doğrulama · Yoklama listesi · Rapor dışı aktarma · Sunucuyla senkron

Korunacak varlıklar:

- QR imza anahtarı – C, I+
- Yoklama kaydı – I+
- Zaman penceresi/geçerlilik süresi – I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** her ders oturumu için kısa ömürlü, imzalı QR üretimi.
- **4.3 Aktarımdaki veri:** taranan QR'ın sunucuya iletiminde yeniden oynatma (replay) engellenir, her QR tek kullanımlık.
- **4.9 Kod sağlamlaştırma:** QR'ı ekran görüntüsüyle paylaşarak tekrar kullanma denemelerine karşı sağlamlaştırma.
- **4.7 Varlık yönetimi:** oturum anahtarlarının ders sonunda geçersiz kılınması.

Sunucu (localhost benzetimi): QR'ın geçerlilik süresini ve tekilliğini denetler.

Genişletme: Birden fazla şube/oturumun eş zamanlı desteklenmesi.

39 — Seçim ve Oylama İstemcisi Benzetimi

Kısa tanım: Küçük ölçekli (örneğin öğrenci konseyi) gizli oylama benzetimi. Saldırgan bir oyu değiştirmek ya da hangi seçmenin neye oy verdiğini öğrenmek isteyen kişidir.

Temel özellikler: Seçmen doğrulama · Oy kullanma · Oyun şifrenmesi · Toplu sayım · Sonuç görüntüleme · Denetim kaydı

Korunacak varlıklar:

- Oy içeriği — C
- Seçmen-oy bağlantısı — C (gizli kalmalı)
- Sayım bütünlüğü — I+
- Denetim kaydı — I+

Öne çıkan gereksinimler:

- **4.2 Kullanımdaki veri:** oy, seçmen kimliğinden ayrıştırılmış biçimde işlenir; ilişkilendirme bellekte tutulmaz.
- **4.4 Beklemedeki veri:** şifreli oylar SQLite'ta saklanır, sayım anına kadar tek tek çözülmez.
- **4.12 Kriptografi ve sertifikalar:** oyların toplu (sayım anında) çözülmesini sağlayan basitleştirilmiş şema.
- **4.13 Sertifikasyon ve sızma testi planı:** oy tekrarı ve seçmen kimliği ilişkilendirme saldırılarına karşı test planı.

Sunucu (localhost benzetimi): Şifreli oyları toplar, her seçmenin yalnız bir kez oy kullanmasını zorlar.

Genişletme: Seçmenin kendi oyunun sayıldığını doğrulayabildiği bir mekanizma.

40 — E-İmza ile Belge İmzalama Aracı

Kısa tanım: Genel amaçlı belge imzalama aracı; sözleşme, dilekçe gibi sentetik belgeleri imzalar. Saldırgan imzalanmış bir belgeyi sonradan değiştirip imzayı hâlâ geçerliymiş gibi göstermek isteyen kişidir.

Temel özellikler: Belge yükleme · İmzalama · Çoklu imzacı desteği · Doğrulama · Zaman damgası · Arşivleme

Korunacak varlıklar:

- İmza özel anahtarı — C
- İmzalı belge özeti — I+
- Sertifika zinciri — I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** OpenSSL ile imzalama, doğrulama ve zaman damgası.
- **4.5 Statik varlıkların korunması:** kök/ara sertifikaların uygulamayla birlikte değiştirilemez dağıtılması.
- **4.1 Geliştirme ortamı güvenliği:** imza özel anahtarının geliştirme/derleme sürecine hiç girmemesi.
- **4.14 Binary uygulama koruması:** imzalama fonksiyonunun ayrıştırılmasına/kopyalanmasına karşı koruma.

Sunucu (localhost benzetimi): Zaman damgası ve sertifika doğrulama hizmeti sunar.

Genişletme: Sıralı çoklu imza akışı (önce hazırlayan, sonra onaylayan imzalar).

41 – Elektronik Kimlik Kartı Okuyucu Benzetimi



Kısa tanım: Sentetik bir e-kimlik kartı verisinin (dosya tabanlı akıllı kart benzetimi) okunup doğrulandığı uygulama. Saldırgan sahte kart verisi üretip gerçek kartmış gibi okutmak isteyen kişidir.

Temel özellikler: Kart verisi okuma (benzetim) · PIN doğrulama · Kimlik bilgisi görüntüleme · İmza doğrulama · Erişim günlüğü · Yanlış PIN'de kart kilitleme

Korunacak varlıklar:

- Kart özel anahtarı (benzetim) – C, I+
- Kimlik verisi (sentetik) – C
- PIN deneme sayacı – I+

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** kart verisinin otorite imzasıyla doğrulanması.
- **4.8 Arayüz tanımları ve korunması:** kart-okuyucu arayüzünün sıkı tanımlanması ve girdi doğrulaması.
- **4.11 Bellek koruması:** PIN'in doğrulama sonrası bellekten güvenli silinmesi.
- **4.10 RASP:** kurcalama/hata ayıklama algılanınca kart oturumunun sonlandırılması.

Sunucu (localhost benzetimi): Kart doğrulaması için kök sertifikayı ve iptal durumunu sağlar.

Genişletme: Temassız (NFC benzetimi) okuma senaryosunun eklenmesi.

42 – Vatandaş Başvuru Formu İstemcisi



Kısa tanım: Sentetik bir kamu hizmeti için başvuru formunun doldurulup gönderildiği uygulama. Saldırgan başkası adına başvuru yapmak ya da mevcut başvuru verisini değiştirmek isteyen kişidir.

Temel özellikler: Form doldurma · Belge ekleme · Başvuru gönderme · Durum sorgulama · Bildirim · Sunucuyla senkron

Korunacak varlıklar:

- Başvuru verisi (sentetik) – C, I
- Ek belgeler – C, I
- Başvuru durumu – I

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** form ve ekler TLS 1.3 üzerinden, bütünlük denetimiyle gönderilir.
- **4.7 Varlık yönetimi:** ek belgelerin özet (hash) ile bütünlüğünün başvuru boyunca izlenmesi.
- **4.15 OWASP ve derleme/dağıtım hattı:** girdi doğrulama, dosya türü/boyut kısıtlaması, güvenli derleme hattı.
- **4.2 Kullanımdaki veri:** form doldurulurken kimlik bilgilerinin bellekte asgari süre tutulması.

Sunucu (localhost benzetimi): Başvuruları alır, durum bilgisini günceller.

Genişletme: Kurum içi çok adımlı onay/yönlendirme sürecinin eklenmesi.

**43 – Onaylı Belge Arşivi**

Kısa tanım: Sentetik resmî belgelerin uzun süre değiştirilemez biçimde arşivlendiği uygulama. Saldırgan arşivdeki bir belgeyi ya da tarihini geriye dönük değiştirmek isteyen kişidir.

Temel özellikler: Belge yükleme · Zaman damgalama · Bütünlük doğrulama · Arama · Sürüm/değişmezlik takibi · Dışa aktarma

Korunacak varlıklar:

- Belge özeti zinciri (hash chain) – **I+**
- Zaman damgaları – **I+**
- Belge içeriği – **C**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** belgeler ve özet zinciri SQLite'ta şifreli saklanır.
- **4.12 Kriptografi ve sertifikalar:** her belge özetinin bir önceki özetle zincirlenip imzalanması.
- **4.7 Varlık yönetimi:** arşive eklenen her belgenin sürüm ve geçmiş kaydının tutulması.
- **4.13 Sertifikasyon ve sızma testi planı:** geçmişe dönük değiştirme (tarih/özet manipülasyonu) senaryolarını kapsayan test planı.

Sunucu (localhost benzetimi): Zaman damgası otoritesi rolünü benzetir.

Genişletme: Özet zincirinin üçüncü tarafça doğrulanabilir açık bir deftere yayınlanması.

44 — Resmî Yazışma İstemcisi

Kısa tanım: Kurumlar arası resmî yazışmanın (sentetik, EBYS benzeri) hazırlanıp imzalandığı uygulama. Saldırgan yazışma içeriğini okumak ya da göndermeden önce değiştirmek isteyen kişidir.

Temel özellikler: Yazı oluşturma · İmzalama · Gönderme/alma · Evrak numarası takibi · Arşivleme · Sunucuyla senkron

Korunacak varlıklar:

- Yazışma içeriği — C, I
- İmza özel anahtarı — C
- Evrak numarası sırası — I+

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** yazışmalar TLS 1.3 üzerinden, uçtan uca şifreli iletilir.
- **4.12 Kriptografi ve sertifikalar:** OpenSSL ile yazının imzalanması ve doğrulanması.
- **4.9 Kod sağlamlaştırma:** yazışma içeriğinin bellek üzerinden okunmasını zorlaştıran sağlamlaştırma.
- **4.8 Arayüz tanımları ve korunması:** imzalama kütüphanesinin dışı açık arayüzünün asgari ve doğrulamalı tutulması.

Sunucu (localhost benzetimi): Evrak numarası tahsis eder, sıranın atlanmamasını sağlar.

Genişletme: Normal/gizli gizlilik dereceli evrak ayrımı.

45 — Pasaport ve Vize Başvuru Takibi

Kısa tanım: Sentetik bir pasaport/vize başvuru sürecinin adım adım takip edildiği uygulama. Saldırgan başvuru durumunu ya da yüklenen belgeleri değiştirmek isteyen kişidir.

Temel özellikler: Başvuru oluşturma · Belge yükleme · Randevu takibi · Durum sorgulama · Bildirim · Sunucuyla senkron

Korunacak varlıklar:

- Başvuru verisi (sentetik) — C, I
- Kimlik belgesi taraması (sentetik) — C
- Durum geçmişi — I

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** başvuru verisi ve belge taramaları SQLite'ta şifreli saklanır.
- **4.3 Aktarımdaki veri:** durum sorgulama ve belge gönderimi TLS 1.3 ile korunur.
- **4.7 Varlık yönetimi:** yüklenen belgelerin bütünlüğünün özetle (hash) izlenmesi.
- **4.2 Kullanımdaki veri:** belge görüntüleme sırasında açık verinin bellekte kısıtlı süre tutulması.

Sunucu (localhost benzetimi): Durum güncellemelerini yayınlar.

Genişletme: Birden fazla ülke/konsolosluk şubesinin desteklenmesi.

46 — Çalışan Kartı ve Kapı Erişim Sistemi

Kısa tanım: Kurumsal kapı erişim kartlarının tanımlandığı ve doğrulandığı bir benzetim uygulaması. Saldırgan yetkisi olmayan bir kapıya girmek ya da bir kartı klonlamak isteyen kişidir.

Temel özellikler: Kart tanımlama · Kapı/bölge yetkisi atama · Erişim doğrulama · Erişim günlüğü · Kart iptali · Sunucuyla senkron

Korunacak varlıklar:

- Kart anahtarı — C, I+
- Yetki listesi — I
- Erişim günlüğü — I+

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** kart-okuyucu arasında karşılıklı kimlik doğrulama.
- **4.3 Aktarımdaki veri:** okuyucu-kart iletişimde yeniden oynatma (replay) engellenir, her istek nonce'lu.
- **4.6 Dinamik varlıkların korunması:** yetki listesinin çalışma zamanında bütünlük denetimi.
- **4.10 RASP:** kart benzetim dosyasında kurcalama algılanınca erişim reddedilir.

Sunucu (localhost benzetimi): İptal edilen kartları ve yetki değişikliklerini dağıtır.

Genişletme: Zaman dilimi bazlı erişim kısıtlaması (mesai saatleri dışında geçersiz kart).

47 — Ziyaretçi Kayıt ve Rozet Sistemi

Kısa tanım: Kurum ziyaretçilerinin (sentetik veri) kaydedilip geçici, imzalı bir rozetle giriş yaptığı uygulama. Saldırgan sahte bir rozet üretip binaya girmek isteyen kişidir.

Temel özellikler: Ziyaretçi kaydı · Sentetik kimlik/fotoğraf ekleme · İmzalı QR rozet üretimi · Giriş-çıkış kaydı · Süre sınırı · Sunucuyla senkron

Korunacak varlıklar:

- Rozet imza anahtarı — C, I+
- Ziyaretçi verisi (sentetik) — C
- Giriş-çıkış kaydı — I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** her rozetin süreli ve imzalı üretilmesi.
- **4.9 Kod sağlama:** rozet QR'nın kopyalanıp çoğaltılmasına karşı sağlama.
- **4.4 Beklemedeki veri:** ziyaretçi kayıtları SQLite'ta şifreli, süre dolunca otomatik temizlenir.
- **4.13 Sertifikasyon ve sızma testi planı:** sahte rozet ve süre uzatma senaryolarını kapsayan test planı.

Sunucu (localhost benzetimi): Geçerli rozetleri ve süre dolumlarını izler.

Genişletme: Önceden yapılan randevuyla otomatik rozet ön onayı.

48 — Tek Oturum Açma (SSO) İstemcisi

Kısa tanım: Kurum içi birden çok uygulamaya tek girişle erişim sağlayan istemci. Saldırgan bir oturum belirtecini (token) çalıp başka bir uygulamada kimliğe bürünmek isteyen kişidir.

Temel özellikler: Kullanıcı doğrulama · Belirteç alma · Uygulamalar arası oturum paylaşımı · Oturum yenileme · Tüm oturumları kapatma · Belirteç iptali

Korunacak varlıklar:

- Oturum belirteci — **C, I+**
- Kullanıcı kimlik bilgisi — **C**
- Yenileme anahtarı (refresh key) — **C**

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** TLS 1.3 ve sertifika sabitleme (pinning) ile belirteç iletimi.
- **4.2 Kullanımdaki veri:** belirtecin bellekte kısa ömürlü tutulması, kullanım sonrası temizlenmesi.
- **4.8 Arayüz tanımları ve korunması:** uygulamalar arası paylaşılan arayüzün asgari ve doğrulamalı tutulması.
- **4.11 Bellek koruması:** yenileme anahtarının bellekte açık biçimde uzun süre tutulmaması.

Sunucu (localhost benzetimi): Belirteç doğrulama ve iptal listesini yönetir.

Genişletme: TOTP tabanlı çok faktörlü doğrulama entegrasyonu.

49 — Biyometrik Şablon Kasası (Benzetim)

Kısa tanım: Sentetik, rastgele üretilmiş biyometrik şablon vektörlerinin (gerçek parmak izi/yüz verisi DEĞİL) saklanıp eşleştirildiği bir benzetim uygulaması. Saldırgan şablonu çalıp başka bir sistemde tekrar kullanmak isteyen kişidir.

Temel özellikler: Şablon kaydı (benzetim sensör verisi) · Eşleştirme (benzetim skoru) · Şablon güncelleme · Erişim günlüğü · Şablon iptali/yeniden kayıt · Sunucuyla senkron

Korunacak varlıklar:

- Biyometrik şablon (sentetik) — **C, I+**
- Eşleştirme skoru eşiği — **I**
- Erişim günlüğü — **I+**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** şablon SQLite'ta şifreli, anahtar SoftHSM'de sarılı tutulur.
- **4.2 Kullanımdaki veri:** şablon yalnız eşleştirme sırasında bellekte açık tutulur, hemen sonra silinir.
- **4.11 Bellek koruması:** eşleştirme fonksiyonunun bellek dökümüne (dump) karşı korunması.
- **4.14 Binary uygulama koruması:** eşleştirme algoritmasının tersine mühendislikle şablon çıkarımına karşı korunması.

Sunucu (localhost benzetimi): Şablonun sürüm/iptal durumunu tutar, yeniden kayıta eskisini geçersiz kılar.

Genişletme: PIN ile benzetim biyometrisinin birlikte kullanıldığı çok faktörlü doğrulama.



50 – Kurumsal Parola Politikası Denetleyicisi



Kısa tanım: Çalışan parolalarının kurum politikasına uyumunu denetleyen ve özetlerini (hash) güvenli saklayan araç. Saldırgan zayıf parolaları öğrenmek ya da denetim raporlarını değiştirmek isteyen kişidir.

Temel özellikler: Politika tanımlama · Parola gücü kontrolü · Parola geçmişi (yeniden kullanım engeli) · Politika denetim raporu · Yerel sızıntı listesiyle kontrol · Sunucuyla senkron

Korunacak varlıklar:

- Parola özetleri (hash + salt) – C, I
- Politika kuralları – I
- Denetim raporu – I+

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** parolalar yalnız tuzlanmış özet olarak SQLite'ta saklanır, açık parola hiç tutulmaz.
- **4.9 Kod sağlama:** özet karşılaştırmasının zamanlama (timing) analizine karşı sabit süreli yapılması.
- **4.1 Geliştirme ortamı güvenliği:** test amaçlı kullanılan örnek parolaların depoya veya günlüklere sızması.
- **4.15 OWASP ve derleme/dağıtım hattı:** bağımlılık taraması ve güvenli derleme hattı ile dağıtım.

Sunucu (localhost benzetimi): Kurum çapında politika kurallarını dağıtır, denetim raporlarını toplar.

Genişletme: Yerel, sentetik bir sızıntı veritabanıyla çapraz kontrol.

51 – Lisanslı İçerik Oynatıcı

Kısa tanım: Kullanıcının satın aldığı ses/görüntü içeriğini çevrimdışı oynatabildiği bir oynatıcı. İçerik şifreli olarak diskte durur, yalnız geçerli lisansla çözülür. Cihaz sahibi aynı zamanda olası saldırıdır: çözülmüş içeriği diskten veya bellekten kopyalamak, lisansı başka cihazda kullanmak ister.

Temel özellikler: İçerik kitaplığı · Lisans etkinleştirme · Çevrimdışı oynatma · Cihaza bağlı lisans · Oynatma oturumu · Lisans yenileme

Korunacak varlıklar:

- İçerik şifreleme anahtarı – **C, I+**
- Çözülmüş içerik arabelleği (bellekte) – **C**
- Lisans belgesi (cihaz kimliği, geçerlilik) – **C, I+**
- Etkinleştirme sayacı – **I+**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** içerik dosyası AES-GCM ile şifreli; anahtar SoftHSM'de saklı, cihaza bağlı.
- **4.6 Dinamik varlıkların korunması:** içerik yalnız oynatma anında parça parça çözülür, tamamı asla diske yazılmaz.
- **4.11 Bellek korunması:** çözülmüş çerçeveler kullanım sonrası güvenli silinir; ekran görüntüsü/kopyalama engeli denenir.
- **4.14 Binary uygulama korunması:** oynatıcı binary dosyası paketlenir/gizlenir; bellek dökümü ve hata ayıklayıcı bağlanmasına karşı kontrol.

Sunucu (localhost benzetimi): İçerik satın alındığında cihaza bağlı lisans üretir, etkinleştirme sayısını sınırlar.

Genişletme: Aynı lisansla sınırlı sayıda cihazda oynatma; lisans iptalinde uzaktan devre dışı bırakma.



52 – Yazılım Lisans Anahtarı Yöneticisi



Kısa tanım: Bir yazılım ürününün lisans anahtarlarını etkinleştiren ve doğrulayan istemci kütüphanesi. Saldırgan yazılımın kullanıcısıdır: sahte anahtar üretmek, kontrolü atlatmak ya da tek bir anahtar çok sayıda makinede kullanmak ister.

Temel özellikler: Anahtar etkinleştirme · Makine parmak izi · Çevrimdışı doğrulama · Süre/sürüm kontrolü · Lisans devri ve iptali

Korunacak varlıklar:

- Lisans anahtarı – C, I+
- İmzalayan genel anahtar – I
- Makine parmak izi – I
- Etkinleştirme sayacı – I+

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** lisans, sunucunun özel anahtarıyla imzalanmış bir blok; istemci yalnız imzayı doğrular.
- **4.9 Kod sağlamlaştırma:** lisans kontrol noktaları koda dağıtılır, tek bir "if" ile atlatılamaz.
- **4.6 Dinamik varlıkların korunması:** geçerlilik çalışma zamanında periyodik olarak yeniden denetlenir.
- **4.13 Sertifikasyon ve sızma testi planı:** anahtar paylaşımı ve binary yama (patch) senaryolarına karşı test planı.

Sunucu (localhost benzetimi): Anahtar üretir, imzalar, etkinleştirme sayısını takip eder ve iptal listesi yayınlar.

Genişletme: Eşzamanlı koltuk sınırlı (floating) lisans havuzu ile ağ üzerinden ödünç kullanım.

**53 – Oyun Kayıt Dosyası Koruyucu**

Kısa tanım: Bir oyunun kayıt (save) dosyalarını bütünlük ve gizlilik açısından koruyan kütüphane. Saldırgan oyuncunun kendisidir: kaydı düzenleyip kaynak/altın/seviye değerini artırmak ya da eski bir kaydı geri yükleyip (rollback) haksız kazanç elde etmek ister.

Temel özellikler: Kayıt serileştirme · Bütünlük imzası · Şifreli kayıt · Sürüm/rollback tespiti · Bozuk kayıt kurtarma

Korunacak varlıklar:

- Kayıt içeriği (ilerleme, envanter) – **I+**
- Kayıt şifreleme anahtarı – **C**
- Bütünlük MAC'i – **I**
- Kayıt sürüm sayacı – **I+**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** kayıt dosyası AES-GCM ile şifreli ve HMAC ile imzalı olarak SQLite'ta durur.
- **4.9 Kod sağlamlaştırma:** anahtar türetme ve bütünlük kontrolü mantığı gizlenir/şaşırtılır.
- **4.11 Bellek koruması:** kayıt anahtarı bellekte kullanım sonrası güvenli silinir.
- **4.14 Binary uygulama koruması:** binary dosya hex-edit ve statik yama denemelerine karşı korunur.

Sunucu (localhost benzetimi): En son geçerli kayıt sürüm numarasını tutar, geriye giden sürümü reddeder.

Genişletme: Bulut yedekli çoklu cihaz senkronizasyonu ve çakışma çözümü.

54 – 🛒 Oyun İçi Mağaza İstemcisi

Kısa tanım: Oyuncunun sanal para ile içerik satın aldığı bir mağaza istemcisi. Saldırgan oyuncudur: yerel sanal bakiyeyi artırmak ya da satın alma isteğini değiştirip ödeme yapmadan içerik almak ister.

Temel özellikler: Ürün kataloğu · Sanal bakiye görüntüleme · Satın alma akışı · Envanter senkronizasyonu · Kampanya/indirim kodu

Korunacak varlıklar:

- Sanal bakiye – **I+**
- Satın alma isteği/yanıtı – **I**
- Oturum belirteci – **C**
- Envanter kaydı – **I+**

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** satın alma isteği TLS 1.3 üzerinden, sunucu tarafından imzalı yanıtla onaylanır.
- **4.2 Kullanımdaki veri:** bakiye yalnız sunucu onayı geldikten sonra yerel arayüzde güncellenir.
- **4.7 Varlık yönetimi:** envanterdeki her ürün sunucu kayıtlarıyla eşleştirilip doğrulanır.
- **4.12 Kriptografi ve sertifikalar:** işlem isteği MAC'li ve sayaçlı, tekrar oynatmaya kapalı.

Sunucu (localhost benzetimi): Bakiye ve envanterin tek otoritesidir; istemcideki yerel değerler asla tek başına güvenilir sayılmaz.

Genişletme: Sınırlı süreli promosyon kodları ve kod tekrar kullanımını engelleme.

**55 — Hileye Dayanıklı Skor Gönderici**

Kısa tanım: Bir oyunun skorunu sunucuya bildiren istemci kütüphanesi. Saldırgan oyuncudur: bellek düzenleyici veya değiştirilmiş bir istemci ile sahte yüksek skor göndermek ister.

Temel özellikler: Oyun oturumu kaydı · Skor hesaplama · Skor imzalama · Sunucuya gönderim · Skor tablosu görüntüleme

Korunacak varlıklar:

- Oturum bütünlük anahtarı — **C**
- Skor ve oynanış özeti — **I+**
- Skor imzalama anahtarı — **C, I+**
- Oturum kimliği — **I**

Öne çıkan gereksinimler:

- **4.10 RASP:** hata ayıklayıcı veya bellek düzenleyici bağlanması algılanınca skor gönderimi reddedilir.
- **4.11 Bellek koruması:** skor ve sayaç değişkenleri şaşırtılır, kontrol toplamıyla izlenir.
- **4.3 Aktarımdaki veri:** skor gönderimi TLS üzerinden, oturum anahtarıyla imzalı olarak yapılır.
- **4.14 Binary uygulama koruması:** istemci ikilisi bellek tarayıcı ve enjeksiyon araçlarına karşı sağlamlaştırılır.

Sunucu (localhost benzetimi): Gelen skoru olabilirlik sınırlarına göre denetler, anormal değerleri işaretler.

Genişletme: Oynanış kaydının (replay) örneklem alınarak sunucuda yeniden hesaplanıp doğrulanması.

56 – Şifreli E-Kitap Okuyucu

Kısa tanım: Satın alınmış e-kitapları çevrimdışı okutan ve düz metnin kolayca çıkarılmasını zorlaştıran bir okuyucu. Saldırgan kullanıcıdır: şifresi çözülmüş metni dışa aktarıp paylaşmak ister.

Temel özellikler: Kitaplık · Lisans/anahtar indirme · Sayfa çözme ve gösterme · Not alma · Yer imi

Korunacak varlıklar:

- Kitap şifreleme anahtarı – **C, I+**
- Çözülmüş sayfa arabelleği – **C**
- Lisans belgesi – **C, I+**
- Kullanıcı notları – **C**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** kitap dosyası diskte AES-GCM ile şifreli tutulur.
- **4.6 Dinamik varlıkların korunması:** yalnız görüntülenen sayfa çözülür, kitabın tamamı asla açık kalmaz.
- **4.5 Statik varlıkların korunması:** kapak görseli ve gömülü fontlar da paketlenip bütünlük özetiyle korunur.
- **4.11 Bellek koruması:** çözülmüş sayfa arabelleği sayfa değişince güvenli silinir.

Sunucu (localhost benzetimi): Satın almada cihaza bağlı anahtar üretir, indirilen başlığı lisansa bağlar.

Genişletme: 14 gün süreli ödünç verme; süre dolunca yerel kopyanın otomatik kilitlenmesi.

57 – Güvenli Not Defteri

Kısa tanım: Kullanıcının özel notlarını yerelde şifreleyip sakladığı bir not defteri. Saldırgan cihaza fiziksel erişimi olan ya da kilitli ekranı atlatmaya çalışan biridir.

Temel özellikler: Ana parola ile kilit · Not oluşturma/düzenleme · Kategori/etiket · Şifreli içerikte arama · Süreyle otomatik kilitlenme

Korunacak varlıklar:

- Not içeriği – **C, I**
- Ana parola özeti – **C**
- Not şifreleme anahtarı – **C**
- Arama dizini – **C**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** notlar SQLite'ta AES-GCM ile şifreli; arama dizini de düz metin bırakmaz.
- **4.2 Kullanımdaki veri:** açık not yalnız bellekte tutulur, ekran kilitlenince görünüm anında temizlenir.
- **4.11 Bellek koruması:** ana parola ve türetilen anahtar kullanım sonrası güvenli silinir.
- **4.1 Geliştirme ortamı güvenliği:** geliştirme ve test sırasında gerçek kişisel not kullanılmaz, yalnız sentetik örnekler.

Sunucu (localhost benzetimi): Opsiyonel; yalnız şifreli yedeklerin zaman damgasını tutan basit bir depo.

Genişletme: Çoklu cihaz arasında uçtan uca şifreli senkronizasyon.

**58 – Uçtan Uca Şifreli Sohbet İstemcisi**

Kısa tanım: İki kullanıcı arasında localhost sunucusu üzerinden mesaj ileten, sunucunun bile içeriği okuyamadığı bir sohbet istemcisi. Saldırgan aradaki sunucuyu veya ağı gözlemleyen biridir.

Temel özellikler: Anahtar değişimi · Mesaj şifreleme/çözme · Yerel mesaj geçmişi · Kimlik parmak izi doğrulama · Bağlantı kopunca yeniden gönderim

Korunacak varlıklar:

- Uzun süreli kimlik anahtarı – **C, I+**
- Oturum/mesaj anahtarı – **C**
- Mesaj içeriği – **C, I**
- Kişi parmak izi listesi – **I**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** anahtar değişimi ve mesaj imzaları asimetrik kriptografi ile yapılır.
- **4.3 Aktarımdaki veri:** sunucu yalnız şifreli metni iletir; içeriği asla çözemez.
- **4.2 Kullanımdaki veri:** açık mesaj yalnız görüntülenirken bellekte tutulur.
- **4.11 Bellek koruması:** oturum anahtarları mesaj sonrası güvenli silinir.

Sunucu (localhost benzetimi): Yalnız şifreli mesajları iletir/kuyruklar; içeriği göremez.

Genişletme: İleri gizlilik (her mesaj için yeni anahtar) ile geçmiş anahtarın ele geçirilmesine karşı koruma.

59 – Şifreli Dosya Paylaşım İstemcisi

Kısa tanım: Kullanıcının dosyalarını localhost sunucusu üzerinden şifreli olarak paylaştığı bir istemci. Saldırgan sunucuyu ya da paylaşım bağlantısını ele geçiren biridir.

Temel özellikler: Dosya şifreleme · Paylaşım bağlantısı/anahtarı üretme · Süreli erişim · Alıcı listesi · İndirme ve çözme

Korunacak varlıklar:

- Dosya şifreleme anahtarı — **C, I+**
- Paylaşım erişim belirteci — **C, I**
- Dosya bütünlük özeti — **I**
- Alıcı listesi — **C**

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** yükleme ve indirme TLS 1.3 üzerinden yapılır.
- **4.4 Beklemedeki veri:** dosya sunucuda yalnız şifreli olarak saklanır, sunucu içeriği çözemez.
- **4.12 Kriptografi ve sertifikalar:** paylaşım anahtarı asimetrik olarak alıcıya sarılır.
- **4.7 Varlık yönetimi:** paylaşılan dosyalar envanterde izlenir; süresi dolan otomatik silinir.

Sunucu (localhost benzetimi): Şifreli dosyayı saklar, erişim belirtecinin süresini ve indirme sayısını denetler.

Genişletme: Bağlantıya ek parola katmanı; bağlantıyı ele geçirene karşı ikinci savunma hattı.

**60 – E-Posta Eki Şifreleyici**

Kısa tanım: Gönderilecek e-posta eklerini şifreleyip yalnız doğru anahtara sahip alıcının açabildiği bir araç. Saldırgan e-postayı yolda ele geçiren ya da yanlış alıcıya ulaşan biridir.

Temel özellikler: Alıcı anahtarı seçme · Ek şifreleme · Alıcıda şifre çözme · Parola ile paylaşım · Ek bütünlük doğrulama

Korunacak varlıklar:

- Ek içeriği – C, I
- Şifreleme anahtarı/parola – C
- Alıcı genel anahtarı – I
- Bütünlük imzası – I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** hibrit şifreleme – içerik simetrik, anahtar alıcının genel anahtarıyla sarılı.
- **4.4 Beklemedeki veri:** şifreli ek gönderilene kadar diskte şifreli tutulur.
- **4.2 Kullanımdaki veri:** açık ek yalnız geçici bir dosyada durur ve gönderim sonrası güvenli silinir.
- **4.8 Arayüz tanımları ve korunması:** e-posta istemcisiyle entegrasyon arayüzü net ve sınırlı tanımlanır.

Sunucu (localhost benzetimi): Yok; localhost yalnız e-posta gönderim kuyruğunu benzetir.

Genişletme: Birden çok alıcı için ayrı ayrı anahtar sarma (çoklu alıcı desteği).

**61 – İmzalı Yazılım Güncelleme İstemcisi**

Kısa tanım: Bir uygulamanın güncellemelerini localhost güncelleme sunucusundan indirip doğrulayan istemci. Saldırgan güncelleme kanalını ele geçirip kötücül bir sürüm dağıtmaya çalışan biridir (tedarik zinciri saldırısı).

Temel özellikler: Sürüm kontrolü · Güncelleme indirme · İmza doğrulama · Sürüm geri alma engeli · Kurulum ve uygulama

Korunacak varlıklar:

- Güncelleme imzalama genel anahtarı – I
- İndirilen paket – I
- Sürüm numarası/geçmişi – I+
- Kurulum günlüğü – I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** her paket imzalanır; istemci imza ve sertifika zincirini doğrular.
- **4.15 OWASP ve derleme/dağıtım hattı:** imzalama anahtarı derleme hattından ayrı, korumalı ortamda tutulur.
- **4.8 Arayüz tanımları ve korunması:** güncelleme API'si sıkı bir şemaya bağlıdır, fazladan alan kabul etmez.
- **4.13 Sertifikasyon ve sızma testi planı:** sahte güncelleme sunucusu (araya girme) senaryosunun test planı.

Sunucu (localhost benzetimi): Her sürüm için imzalı manifesto ve paket sunan basit bir sürüm deposu.

Genişletme: Kademeli dağıtım (kullanıcıların yüzde X'ine önce) ve sorunlu sürümde otomatik geri alma.



62 – İmzalı Eklenti Yükleyici



Kısa tanım: Ana uygulamanın yalnız imzalı ve güvenilir eklentileri yüklemesini sağlayan bir çekirdek. Saldırgan kötücül bir eklentiyi normal bir eklenti gibi göstermeye çalışan biridir.

Temel özellikler: Eklenti kataloğu · İmza doğrulama · Eklenti yükleme/kaldırma · İzin/kapsam tanımlama · Eklenti güncelleme

Korunacak varlıklar:

- Eklenti imzalama anahtarı – I
- Eklenti binary dosyası – I
- İzin/kapsam tanımı – I
- Güvenilir yayıncı listesi – I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** eklenti imzası ve yayıncı sertifikası yükleme öncesi doğrulanır.
- **4.8 Arayüz tanımları ve korunması:** eklenti API'si sürümlü ve sınırlı yeteneklerle tanımlanır.
- **4.9 Kod sağlamlaştırma:** imza kontrolü erken aşamada çalışır ve atlatılamayacak şekilde gizlenir.
- **4.5 Statik varlıkların korunması:** eklenti paketleri bütünlük özetiyle depoda saklanır.

Sunucu (localhost benzetimi): Opsiyonel eklenti kataloğu sunucusu; imzalı eklentileri barındırır.

Genişletme: Eklenti sanal alanı (sandbox) ile eklentinin erişebileceği kaynakları kısıtlama.



63 – Yapılandırma Sırları Kasası



Kısa tanım: Bir uygulamanın veritabanı parolası, API anahtarı gibi yapılandırma sırlarını sakladığı bir kasa kütüphanesi. Saldırgan yapılandırma dosyasına, günlüklere veya belleğe erişen biridir.

Temel özellikler: Sır ekleme/güncelleme · Ortam bazlı yapılandırma (geliştirme/üretim) · Sır okuma API'si · Erişim günlüğü · Sır rotasyonu

Korunacak varlıklar:

- Sır değerleri — **C, I+**
- Ana şifreleme anahtarı — **C**
- Erişim günlüğü — **I**
- Ortam etiketleri — **I**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** sırlar SQLite'ta şifreli tutulur, düz metin dosyaya asla yazılmaz.
- **4.1 Geliştirme ortamı güvenliği:** geliştirmede örnek/placeholder sırlar kullanılır, gerçek sır koda gömülmez.
- **4.7 Varlık yönetimi:** her sırrın yaşam döngüsü (oluşturma, rotasyon, iptal) izlenir.
- **4.11 Bellek koruması:** ana anahtar bellekte yalnız gerektiğinde açılır, sonrasında silinir.

Sunucu (localhost benzetimi): Yok; localhost yalnız rotasyon zamanlayıcısını benzetir.

Genişletme: Rol bazlı erişim kontrolü ile hangi bileşenin hangi sırrı okuyabileceğinin sınırlanması.

**64 — API Geliştirici API Anahtarı Yöneticisi**

Kısa tanım: Geliştiricilerin kendi API anahtarlarını oluşturup yönettiği bir araç. Saldırgan çalınan bir anahtar sınırsız kullanmak isteyen biri ya da anahtar günlüğe/depoya sızdıran ihmalkâr bir geliştiricidir.

Temel özellikler: Anahtar oluşturma · Kapsam/izin atama · Anahtar listeleme (yalnız özet gösterimi) · Anahtar iptali · Kullanım günlüğü

Korunacak varlıklar:

- API anahtarı — C, I+
- Anahtar özeti (hash) — I
- Kapsam tanımı — I
- Kullanım günlüğü — I

Öne çıkan gereksinimler:

- **4.7 Varlık yönetimi:** anahtarların oluşturma, rotasyon ve iptal yaşam döngüsü izlenir.
- **4.4 Beklemedeki veri:** yalnız anahtarın özeti saklanır; ham anahtar bir kez, yalnız oluşturulduğunda gösterilir.
- **4.1 Geliştirme ortamı güvenliği:** anahtarlar günlüğe, sürüm kontrolüne veya koda asla yazılmaz.
- **4.8 Arayüz tanımları ve korunması:** API kapsamları en az yetki ilkesiyle dar tanımlanır.

Sunucu (localhost benzetimi): Gelen isteği anahtar özetiyle doğrular, kapsam dışı istekleri reddeder.

Genişletme: Anahtar başına oran sınırlama (rate limiting) ve anormal kullanım uyarısı.

**65 – Kod İmzalama Aracı**

Kısa tanım: Geliştiricinin derlediği binary dosyaları imzalamak için kullandığı bir araç; imzalama anahtarı yerel bir donanım güvenlik modülü benzetiminde tutulur. Saldırgan imzalama anahtarını çalıp sahte binary imzalamak isteyen biridir.

Temel özellikler: Anahtar çifti oluşturma · Binary dosya özetleme · SoftHSM üzerinden imzalama · İmza doğrulama · Genel anahtar/sertifika dışı aktarma

Korunacak varlıklar:

- İmzalama özel anahtarı – C, I+
- Binary dosya özeti – I
- Üretilen imza – I
- Anahtar kullanım günlüğü – I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** özel anahtar [SoftHSM/PKCS#11](#) içinde tutulur, hiçbir zaman dışı çıkmaz.
- **4.1 Geliştirme ortamı güvenliği:** imzalama yalnız yetkili, ağdan izole derleme makinesinde çalışır.
- **4.13 Sertifikasyon ve sızma testi planı:** anahtar sızıntısı ve yetkisiz imzalama senaryosu test planına dahil edilir.
- **4.7 Varlık yönetimi:** imzalanan her binary dosyanın envanteri ve zaman damgası tutulur.

Sunucu (localhost benzetimi): Yok; localhost yalnız bir zaman damgalama (timestamping) benzetimi sunar.

Genişletme: Çoklu imza (iki geliştiricinin onayı) ile kritik sürümlerin imzalanması.

**66 – Şifreli ve Sürümlü Yedekleme İstemcisi**

Kısa tanım: Kullanıcı dosyalarını şifreli olarak localhost yedekleme sunucusuna gönderen, sürüm geçmişini tutan bir istemci. Saldırgan yedekleme sunucusunu veya aktarımı ele geçiren biridir.

Temel özellikler: Dosya seçimi · Artımlı yedekleme · Şifreleme · Sürüm geçmişi ve geri yükleme · Bütünlük doğrulama

Korunacak varlıklar:

- Yedekleme şifreleme anahtarı – **C, I+**
- Yedek içeriği – **C, I**
- Sürüm meta verisi – **I**
- Bütünlük özeti – **I**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** sunucudaki yedek parçaları uçtan uca şifreli tutulur.
- **4.3 Aktarımdaki veri:** yedekleme trafiği TLS 1.3 ile korunur.
- **4.7 Varlık yönetimi:** sürüm listesi ve saklama süresi politikası izlenir.
- **4.11 Bellek koruması:** yedekleme anahtarı bellekte yalnız aktarım süresince açık tutulur.

Sunucu (localhost benzetimi): Şifreli yedek parçalarını ve sürüm listesini saklar; içeriği çözemez.

Genişletme: 3-2-1 yedekleme stratejisi benzetimi (ikinci yerel kopya ile).

67 – Güvenli Pano Yöneticisi

Kısa tanım: Panoya (clipboard) kopyalanan hassas verileri (parola gibi) şifreli geçmişte tutan ve süresi dolunca otomatik temizleyen bir araç. Saldırgan aynı cihazdaki başka bir uygulama veya kullanıcıdır.

Temel özellikler: Pano geçmişi kaydı · Süreyle otomatik temizleme · Hassas veri işaretleme · Şifreli geçmişte arama · Manuel silme

Korunacak varlıklar:

- Pano geçmişi içeriği – **C**
- Geçmiş şifreleme anahtarı – **C**
- Hassas veri etiketleri – **C**
- Erişim günlüğü – **I**

Öne çıkan gereksinimler:

- **4.2 Kullanımdaki veri:** hassas pano verisi bellekte en kısa sürede tutulup hemen temizlenir.
- **4.11 Bellek koruması:** kopyalanan değerlerin bellekteki tüm kopyaları güvenli silinir.
- **4.4 Beklemedeki veri:** pano geçmişi SQLite'ta şifreli saklanır.
- **4.9 Kod sağlamlaştırma:** hassas veri algılama mantığı basit atlatma denemelerine karşı sağlamlaştırılır.

Sunucu (localhost benzetimi): Yok; localhost yalnız opsiyonel çoklu cihaz senkronizasyonunu benzetir.

Genişletme: Uygulama bazlı pano erişim izni; yalnız izinli uygulamalar geçmiş okuyabilir.

**68 – Belge Filigranlayıcı**

Kısa tanım: Paylaşılan belgelere görünür ve görünmez filigran (kullanıcı kimliği, zaman damgası) ekleyip sızıntı kaynağını izlenebilir kılan bir araç. Saldırgan filigranı kaldırıp belgeyi izinsiz paylaşan biridir.

Temel özellikler: Belge yükleme · Görünür filigran · Dayanıklı görünmez filigran gömme · Filigran çıkarma ve doğrulama · Belge envanteri

Korunacak varlıklar:

- Filigran anahtarı/tohumu – C, I
- Belge içeriği – C
- Filigran-kullanıcı eşleşmesi – I
- Belge envanteri – I

Öne çıkan gereksinimler:

- **4.5 Statik varlıkların korunması:** dağıtılan belgeler filigranlı statik varlık olarak bütünlük özetiyle korunur.
- **4.7 Varlık yönetimi:** hangi belgenin kime, ne zaman dağıtıldığı izlenir.
- **4.9 Kod sağlamlaştırma:** filigran gömme/çıkarma mantığının kolayca tersine çevrilmesi zorlaştırılır.
- **4.6 Dinamik varlıkların korunması:** her indirmede kullanıcıya özgü filigranlı kopya anında üretilir.

Sunucu (localhost benzetimi): Her belge isteğinde kullanıcıya özgü filigranlı kopya üretir, eşleşmeyi kaydeder.

Genişletme: Filigran çıkarma aracı ile sızan bir belgeden kaynağın tespiti.

69 – Şifreli Fotoğraf Galerisi



Kısa tanım: Kullanıcının fotoğraflarını yerelde şifreli albüm hâlinde sakladığı bir galeri uygulaması. Saldırgan cihaza erişimi olan ya da yedek dosyasını ele geçiren biridir.

Temel özellikler: Fotoğraf içe aktarma · Şifreli depolama · Albüm/etiketleme · Küçük resim (thumbnail) önizleme · Güvenli silme

Korunacak varlıklar:

- Fotoğraf dosyaları – C
- Küçük resim önbellege – C
- Galeri şifreleme anahtarı – C
- Albüm meta verisi – C

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** fotoğraflar ve küçük resimler AES-GCM ile şifreli tutulur.
- **4.5 Statik varlıkların korunması:** önbelleg/thumbnail dosyaları da şifreli, düz metin artık bırakmaz.
- **4.11 Bellek koruması:** açık görüntü arabelleği görüntüleme sonrası güvenli silinir.
- **4.6 Dinamik varlıkların korunması:** önizleme yalnız görüntülenirken çözülür, toplu çözme yapılmaz.

Sunucu (localhost benzetimi): Yok; localhost yalnız opsiyonel şifreli yedekleme benzetimi sağlar.

Genişletme: Albüm paylaşımı için süreli ve ayrı anahtarlı paylaşım bağlantısı.

**70 — Şifreli Sesli Not Kaydedici**

Kısa tanım: Kullanıcının sesli notlarını kaydedip şifreli sakladığı bir uygulama. Saldırgan cihaza erişimi olan ya da paylaşılan kaydı ağdan ele geçiren biridir.

Temel özellikler: Ses kaydı · Şifreli depolama · Oynatma · Not/etiket ekleme · Localhost üzerinden paylaşım

Korunacak varlıklar:

- Ses kaydı dosyası — **C**
- Kayıt şifreleme anahtarı — **C**
- Not/etiket meta verisi — **C**
- Paylaşım erişim belirteci — **C, I**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** kayıtlar AES-GCM ile şifreli olarak diskte tutulur.
- **4.2 Kullanımdaki veri:** kayıt sırasında ham ses tamponu yalnız bellekte durur, diske yazılmaz.
- **4.11 Bellek koruması:** ses tamponu kayıt bitince güvenli silinir.
- **4.3 Aktarımdaki veri:** paylaşım TLS ile ve süreli erişim belirteciyle yapılır.

Sunucu (localhost benzetimi): Yalnız paylaşılan kayıtları geçici olarak şifreli tutar, süresi dolunca siler.

Genişletme: Çevrimdışı, yerel konuşmadan metne dönüştürme benzetimi ile otomatik not özeti.

71 – Süreli Lisanslı İçerik İndirici



Kısa tanım: Kullanıcının sınırlı süreliğine (ör. 48 saat) indirip izleyebildiği lisanslı içerik istemcisi. Saldırgan süre dolduktan sonra da içeriği kullanmaya devam etmek isteyen kullanıcıdır.

Temel özellikler: İçerik indirme · Süreli lisans · Geri sayım/süre kontrolü · Süre dolunca otomatik silme · Yeni lisansla yeniden indirme

Korunacak varlıklar:

- İçerik şifreleme anahtarı – **C, I+**
- Lisans son kullanma zamanı – **I+**
- İndirilen içerik – **C**
- Cihaz saati referansı – **I**

Öne çıkan gereksinimler:

- **4.6 Dinamik varlıkların korunması:** süre kontrolü her oynatmada sunucu zaman damgasıyla yeniden denetlenir.
- **4.3 Aktarımdaki veri:** indirme ve lisans yenileme TLS ile korunur.
- **4.12 Kriptografi ve sertifikalar:** lisans imzalı; süre alanı istemci tarafından değiştirilemez.
- **4.14 Binary uygulama koruması:** süre kontrolünün atlatılmasına karşı binary dosya sağlamlaştırılır.

Sunucu (localhost benzetimi): İçerik ve süreli lisansı verir; sunucu saatiyle imzalı son kullanma zamanı üretir.

Genişletme: Süre bitmeden bildirim gönderme ve tek tıkla yeniden kiralama.

72 – Çevrimdışı Harita Paketi Lisans Denetimi



Kısa tanım: Kullanıcının çevrimdışı kullanmak üzere indirdiği harita paketlerinin lisansını denetleyen bir istemci. Saldırgan bir bölge paketini satın almadan tüm haritayı kullanmak isteyen kullanıcıdır.

Temel özellikler: Bölge paketi kataloğu · Paket indirme · Lisans/bölge eşleştirme · Çevrimdışı harita görüntüleme · Paket güncelleme

Korunacak varlıklar:

- Harita paket dosyası – I
- Bölge lisans kaydı – I+
- Paket bütünlük özeti – I
- Lisans-paket imzası – I

Öne çıkan gereksinimler:

- **4.5 Statik varlıkların korunması:** harita paketleri bütünlük özetiyle korunur; değiştirilmiş paket reddedilir.
- **4.6 Dinamik varlıkların korunması:** yalnız lisanslı bölge açılır, diğer bölgeler kilitli kalır.
- **4.12 Kriptografi ve sertifikalar:** lisans-paket eşleşmesi imzalı olarak dağıtılır.
- **4.13 Sertifikasyon ve sızma testi planı:** paket değiştirme ve bölge sınırını atlatma senaryosu test planına dahil edilir.

Sunucu (localhost benzetimi): Satın alınan bölge için imzalı paket ve lisans üretir.

Genişletme: Paket içinde yol/POI gibi alt katmanların ayrı ayrı lisanslanması.

**73 – Oyun Hile Tespit Kütüphanesi**

Kısa tanım: Bir oyuna gömülen, bellek düzenleyici, hata ayıklayıcı ve kod enjeksiyon araçlarını tespit eden kütüphane. Saldırgan oyuncudur: bellek tarayıcıyla değer değiştirmek ya da kod enjekte etmek ister.

Temel özellikler: Süreç/bellek bütünlüğü tarama · Hata ayıklayıcı tespiti · Bilinen hile aracı imzası eşleştirme · İhlal bildirimi · Oyunu güvenli sonlandırma

Korunacak varlıklar:

- Tespit imza veritabanı – I
- Bütünlük taban çizgisi (referans özet) – I
- İhlal günlüğü – I
- Tespit parametreleri – C

Öne çıkan gereksinimler:

- **4.10 RASP:** çalışma zamanında kurcalama tespit edilir ve anında tepki verilir (oturum sonlandırma).
- **4.11 Bellek koruması:** kütüphanenin kendi tespit değişkenleri de kurcalamaya karşı korunur.
- **4.9 Kod sağlamlaştırma:** tespit mantığı tersine mühendisliğe karşı gizlenir/şaşırtılır.
- **4.8 Arayüz tanımları ve korunması:** oyun ile kütüphane arasındaki arayüz kötüye kullanılamayacak şekilde dar tutulur.

Sunucu (localhost benzetimi): İhlal bildirimlerini toplar, tekrarlayan ihlallerde hesabı işaretler.

Genişletme: Davranışsal anomali tespiti (olağandışı hız/isabet oranı) ile imza tabanlı tespitin desteklenmesi.

74 – Dijital Etkinlik Bileti Cüzdanı

Kısa tanım: Kullanıcının satın aldığı etkinlik biletlerini QR kod olarak sakladığı ve girişte doğrulanan bir cüzdan. Saldırgan bileti çoğaltıp (ekran görüntüsü) aynı anda birden çok kişiyle içeri girmek isteyen kullanıcıdır.

Temel özellikler: Bilet satın alma · QR kod üretimi · Çevrimdışı görüntüleme · Giriş noktasında doğrulama · Bilet transferi

Korunacak varlıklar:

- Bilet imzalama anahtarı – C, I+
- Bilet kimliği ve kullanım durumu – I+
- QR kod içeriği – I
- Transfer kaydı – I

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** bilet imzalıdır; sahte QR kod üretilemez.
- **4.6 Dinamik varlıkların korunması:** QR kod kısa aralıklarla yenilenir, ekran görüntüsü paylaşımını zorlaştırır.
- **4.3 Aktarımdaki veri:** giriş noktası doğrulaması TLS ile sunucuya sorulur.
- **4.14 Binary uygulama koruması:** bilet verisinin istemci tarafında değiştirilmesine karşı koruma sağlanır.

Sunucu (localhost benzetimi): Bilet kullanım durumunu tutar; bir bileti yalnız bir kez geçerli sayar, çift kullanımı reddeder.

Genişletme: Bilet transferinde eski QR kodun anında geçersiz kılınması.

**75 – Süreli Film Kiralama İstemcisi**

Kısa tanım: Kullanıcının belirli bir süre için (ör. ilk oynatmadan başlayan 48 saatlik izleme penceresi) film kiraladığı bir istemci. Saldırgan süre kısıtını atlatıp süresiz izlemek isteyen kullanıcıdır.

Temel özellikler: Film kataloğu · Kiralama satın alma · İlk oynatmada süre başlatma · Geri sayım · Süre dolunca erişimi kapatma

Korunacak varlıklar:

- Film şifreleme anahtarı – **C, I+**
- Kiralama başlangıç/bitiş zamanı – **I+**
- Çözülmüş kare arabelleği – **C**
- Lisans belgesi – **C, I+**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** film dosyası diskte şifreli tutulur.
- **4.6 Dinamik varlıkların korunması:** süre başlangıcı sunucuyla eşleşir; yerel saat değişikliği süreyi geçersiz kılar.
- **4.11 Bellek koruması:** çözülmüş kareler bellekte kısa ömürlüdür, kullanım sonrası silinir.
- **4.14 Binary uygulama koruması:** süre/oynatma kontrolünün yama ile atlatılmasına karşı sağlamlaştırma yapılır.

Sunucu (localhost benzetimi): İlk oynatma bildirimini alır, kiralama penceresinin bitiş zamanını imzalı olarak döner.

Genişletme: İndirilmiş kiralamanın çevrimdışı süre takibi ile periyodik çevrimiçi doğrulama zorunluluğu.

76 – Akıllı Kilit Kontrol İstemcisi

Kısa tanım: Bluetooth/Wi-Fi üzerinden akıllı kapı kilidini açıp kapatan bir masaüstü istemci; gerçek bir kilit donanımına bağlanılmaz, kilit sunucu tarafında yazılım benzetimiyle temsil edilir. Cihazı ele geçiren ya da iletişimi dinleyen bir saldırgan kilidi izinsiz açmak veya erişim kaydını gizlemek ister.

Temel özellikler: Kullanıcı eşleştirme (pairing) · PIN/parola ile kilit açma-kapama · Geçici misafir kodu üretme · Erişim geçmişi görüntüleme · Uzaktan kilit durumu sorgulama

Korunacak varlıklar:

- Kilit açma komutu ve eşleştirme anahtarı – **C, I+**
- PIN/misafir kodu – **C, I**
- Erişim (açma-kapama) geçmişi – **I+** (silinmemeli, geriye dönük değiştirilmemeli)
- Cihaz kimlik sertifikası – **I**

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** kilit komutu TLS ile şifreli ve zaman damgalı gönderilir; tekrar oynatma (replay) engellenir.
- **4.12 Kriptografi ve sertifikalar:** her cihazın kendine özgü eşleştirme sertifikası vardır, sahte cihaz kabul edilmez.
- **4.10 RASP:** hata ayıklayıcı bağlantısı ya da bellek kurcalama tespit edilince açma komutu reddedilir.
- **4.4 Beklemedeki veri:** PIN ve anahtarlar SQLite'ta şifreli, düz metin tutulmaz.

Sunucu (localhost benzetimi): Kilit durumunu ve eşleştirilmiş cihaz listesini tutar, sahte/eşleşmemiş cihazdan gelen komutu reddeder.

Genişletme: Birden çok kullanıcıya zaman sınırlı erişim yetkisi tanımlama (ör. temizlikçi için sadece 09:00–11:00).

77 – Akıllı Ev Ağ Geçidi Yapılandırıcı

Kısa tanım: Ev içi IoT cihazlarını (lamba, priz, sensör benzetimleri) tek bir ağ geçidi üzerinden yöneten yapılandırma istemcisi; gerçek donanıma bağlanılmaz, cihazlar yerel süreçler/localhost uç noktaları ile benzetilir. Ağa sızan bir saldırgan cihaz listesini değiştirmek ya da sahte cihaz eklemek ister.

Temel özellikler: Cihaz keşfi ve eşleştirme · Wi-Fi kimlik bilgisi dağıtımı · Sahne/otomasyon kuralı tanımlama · Ürün yazılımı güncelleme tetikleme · Cihaz durumu izleme

Korunacak varlıklar:

- Wi-Fi kimlik bilgileri – **C**
- Cihaz eşleştirme anahtarları – **C, I+**
- Ürün yazılımı güncelleme paketi – **I+** (imzasız kabul edilmez)
- Cihaz envanteri/yapılandırma – **I**

Öne çıkan gereksinimler:

- **4.7 Varlık yönetimi:** her cihazın kimliği, anahtarı ve son görülme zamanı envanterde tutulur; kayıp cihaz iptal edilir.
- **4.8 Arayüz tanımları ve korunması:** ağ geçidi–cihaz protokolü sürümlenir, tanımsız komut reddedilir.
- **4.3 Aktarımdaki veri:** Wi-Fi kimlik bilgisi dağıtımı uçtan uca şifreli kanalla yapılır.
- **4.1 Geliştirme ortamı güvenliği:** derleme sırasında test anahtarları üretime sızmaz.

Sunucu (localhost benzetimi): Eşleştirilmiş cihaz kimliklerini ve ürün yazılımı imza anahtarını tutar, imzasız güncellemeyi reddeder.

Genişletme: Misafir ağı için cihaz görünürlüğünü sınırlayan ayrı bir güven bölgesi.

78 — Akıllı Elektrik Sayacı Veri Toplayıcı



Kısa tanım: Akıllı elektrik sayacından (yazılım benzetimi) periyodik tüketim verisi toplayıp faturalama sunucusuna ileten bir istemci. Ev sahibi aynı zamanda olası saldırgandır: tüketimi düşük göstererek fatura kaçırmak ister.

Temel özellikler: Periyodik ölçüm okuma · Yerel önbellekte biriktirme · Sunucuya toplu gönderim · Sayaç kimlik doğrulama · Kesinti sonrası veri bütünlüğü kontrolü

Korunacak varlıklar:

- Tüketim ölçümleri — **I+** (geriye dönük değiştirilmemeli, sayaç geri sarılmamalı)
- Sayaç kimlik sertifikası — **I**
- İletim oturum anahtarı — **C**
- Yerel önbellek dosyası — **C, I**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** yerel önbellek AES-GCM ile şifreli, sayaç kimliğine bağlı anahtarla açılır.
- **4.12 Kriptografi ve sertifikalar:** her ölçüm gönderimi sayaç sertifikasıyla imzalanır.
- **4.9 Kod sağlamlaştırma:** ölçüm hesaplama mantığı gizlenir, kolay yama ile değiştirilemez.
- **4.3 Aktarımdaki veri:** sunucuya iletim TLS 1.3 + karşılıklı kimlik doğrulama ile yapılır.

Sunucu (localhost benzetimi): Sayaç kimliğine göre son okunan değeri tutar, geri sarılmış veya imzasız ölçümü reddeder.

Genişletme: Kaçırılan iletim pencerelerini tespit edip alarm üreten bir izleme paneli.

79 – Elektrikli Araç Şarj İstasyonu İstemcisi

Kısa tanım: Elektrikli araç şarj istasyonunu (yazılım benzetimi) başlatıp durduran, tüketilen enerjiyi ve ücreti hesaplayan bir istemci; gerçek şarj donanımına bağlanılmaz. Kötü niyetli kullanıcı şarj süresini/miktarını düşük göstererek ödemeden kaçınmak ister.

Temel özellikler: Kullanıcı kimlik doğrulama · Şarj oturumu başlatma-durdurma · Anlık güç/enerji göstergesi · Ödeme token'ı ile ücretlendirme · Oturum makbuzu

Korunacak varlıklar:

- Şarj oturumu verisi (kWh, süre) – I+
- Ödeme token'ı – C
- İstasyon kimlik sertifikası – I
- Oturum makbuzu – I+

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** istasyon-sunucu iletişimi TLS ile ve karşılıklı sertifika doğrulamayla korunur.
- **4.2 Kullanımdaki veri:** ödeme token'ı bellekte yalnız işlem anında açık tutulur, sonrasında temizlenir.
- **4.12 Kriptografi ve sertifikalar:** oturum makbuzu istasyon anahtarıyla imzalanır.
- **4.13 Sertifikasyon ve sızma testi planı:** ödeme akışı için ayrı bir sızma testi senaryosu tanımlanır.

Sunucu (localhost benzetimi): Açık oturumları ve tüketilen enerjiyi tutar, imzasız/tutarsız kapatma isteğini reddeder.

Genişletme: Aynı anda birden çok şarj noktasını yöneten bir istasyon filosu görünümü.

**80 – Araç Arıza Teşhis (OBD) Veri Kaydedici**

Kısa tanım: Araç OBD arayüzünden (yazılım benzetimi, gerçek araca bağlanılmaz) arıza kodu ve kilometre bilgisini okuyup imzalı biçimde kaydeden bir istemci. Aracı satmadan önce kilometreyi düşürmek isteyen sahip, olası saldırgandır.

Temel özellikler: Arıza kodu (DTC) okuma · Kilometre kaydı · Servis geçmişi görüntüleme · Kayıt dışı aktarma (rapor) · Cihaz kimlik doğrulama

Korunacak varlıklar:

- Kilometre kaydı – I+ (geriye dönük azaltılamaz)
- Arıza kodu geçmişi – I+
- OBD cihaz kimliği – I
- Dışa aktarılan rapor – I+

Öne çıkan gereksinimler:

- **4.14 Binary uygulama koruması:** kilometre hesaplama mantığı tersine mühendisliğe karşı sertleştirilir.
- **4.9 Kod sağlamlaştırma:** bellek üzerinde değer değiştirmeye (ör. hile motoru) karşı kontrol toplamları kullanılır.
- **4.4 Beklemedeki veri:** kayıtlar SQLite'ta imzalı ve şifreli tutulur, tekil artan sayaçla korunur.
- **4.11 Bellek koruması:** kilometre değeri işlem sırasında güvenli bellek bölgesinde tutulur.

Sunucu (localhost benzetimi): Araç kimliğine göre en son bildirilen kilometreyi tutar, azalan değeri reddeder.

Genişletme: Servis geçmişini zincirleme özetlerle (hash chain) bağlayıp bütünlüğü doğrulama.

81 – İmzalı GPS Kayıtlı Filo Takibi

Kısa tanım: Filodaki araçların (yazılım benzetimi) konum bilgisini periyodik olarak imzalayıp merkezi sunucuya ileten bir istemci. Sürücü, mesai dışı kullanım ya da rota sapmasını gizlemek için konum kaydını değiştirmek isteyebilir.

Temel özellikler: Periyodik konum örnekleme · Yerel imzalı günlük tutma · Sunucuya toplu senkronizasyon · Rota geçmişi görüntüleme · Cihaz-sürücü eşleştirme

Korunacak varlıklar:

- GPS konum günlüğü – **I+** (imzalı, sırası bozulmamalı)
- Cihaz imzalama anahtarı – **C, I+**
- Sürücü kimliği – **C**
- Senkronizasyon oturum anahtarı – **C**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** her konum kaydı cihaz özel anahtarıyla imzalanır; anahtar SoftHSM'de sarılı tutulur.
- **4.4 Beklemedeki veri:** yerel günlük şifreli ve artan sıra numarasıyla korunur, araya kayıt sıkıştırılamaz.
- **4.3 Aktarımdaki veri:** senkronizasyon TLS 1.3 ile yapılır, kesintide kaldığı yerden devam eder.
- **4.7 Varlık yönetimi:** araç-anahtar eşlemesi merkezi envanterde tutulur, kayıp cihaz iptal edilir.

Sunucu (localhost benzetimi): Araç başına son sıra numarasını tutar, imzasız veya sıra atlayan kaydı reddeder.

Genişletme: Rota dışı çıkışlarda otomatik uyarı üreten basit bir coğrafi sınır (geofence) denetimi.



82 – Dijital Takograf Benzetimi



Kısa tanım: Sürücü çalışma/dinlenme sürelerini kaydeden dijital takografin yazılım benzetimi; gerçek araç donanımına bağlanılmaz. Sürücü, izin verilen süreyi aşmamak için kayıtları geriye dönük değiştirmek isteyebilir.

Temel özellikler: Sürücü kartı (benzetim) ile oturum açma · Sürüş/mola durumu kaydı · Günlük özet raporu · Kayıt dışı aktarma · Denetim modu görüntüleme

Korunacak varlıklar:

- Sürüş/mola süre kayıtları – I+ (geçmişe dönük değiştirilemez)
- Sürücü kartı verisi (benzetim) – C
- Denetim raporu – I+
- Cihaz saat/zaman damgası – I

Öne çıkan gereksinimler:

- **4.14 Binary uygulama koruması:** uygulamanın hile araçlarıyla (debugger/patch) değiştirilmesine karşı bütünlük denetimi.
- **4.10 RASP:** kurcalama tespit edilince kayıt modu askıya alınır ve olay işaretlenir.
- **4.12 Kriptografi ve sertifikalar:** günlük özet, cihaz sertifikasıyla imzalanır.
- **4.4 Beklemedeki veri:** kayıtlar ekleme-yalnız (append-only) yapıda, önceki imza zincire dahil edilerek saklanır.

Sunucu (localhost benzetimi): Sürücü başına gönderilen günlük özetleri saklar, zincir kopukluğunu tespit edip reddeder.

Genişletme: Aşırı sürüş süresi ihlallerinde otomatik uyarı üreten basit bir denetim paneli.

83 – Kargo Teslimat Doğrulama Sistemi



Kısa tanım: Kurye tarafından teslimatın imzalı kanıtla (alıcı imzası/kod benzetimi) onaylandığı bir istemci-sunucu sistemi. Kurye ya da alıcı, teslimatı gerçekleşmemiş gibi ya da farklı gösterip anlaşmazlık çıkarmak isteyebilir.

Temel özellikler: Teslimat listesi görüntüleme · Alıcı kimlik/kod doğrulama · Teslimat kanıtı (imza/foto benzetimi) alma · Durum güncelleme · Teslimat geçmişi sorgulama

Korunacak varlıklar:

- Teslimat kanıtı – **I+** (imzalı, sonradan değiştirilemez)
- Alıcı doğrulama kodu – **C**
- Kurye kimlik sertifikası – **I**
- Teslimat durumu günlüğü – **I+**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** teslimat kanıtı kurye cihazının özel anahtarıyla imzalanır.
- **4.3 Aktarımdaki veri:** durum güncellemeleri TLS ile ve zaman damgalı gönderilir.
- **4.8 Arayüz tanımları ve korunması:** kurye-sunucu API'si sürümlenir, geçersiz durum geçişleri reddedilir.
- **4.7 Varlık yönetimi:** kurye cihaz kimlikleri ve anahtarları merkezi listede tutulur, iptal edilebilir.

Sunucu (localhost benzetimi): Gönderi kimliğine göre son durumu tutar, imzasız veya tutarsız durum geçişini reddeder.

Genişletme: Alıcının teslimatı kendi cihazından ikinci bir imzayla onaylaması (çift taraflı kanıt).

84 — Yetkili Erişimli Depo Stok Yönetimi

Kısa tanım: Depo görevlilerinin roller bazında (görevli/denetçi/yönetici) stok giriş-çıkışı yaptığı bir masaüstü uygulaması. Yetkisi düşük bir görevli, stok kaydını kendi lehine değiştirmek ya da yetkisini yükseltmek isteyebilir.

Temel özellikler: Rol tabanlı oturum açma · Stok giriş/çıkış kaydı · Sayım (envanter) raporu · Kritik işlemler için onay zinciri · Denetim günlüğü görüntüleme

Korunacak varlıklar:

- Stok miktarı kayıtları — I+
- Kullanıcı rol/yetki bilgisi — C, I
- Denetim (audit) günlüğü — I+
- Onay zinciri imzaları — I+

Öne çıkan gereksinimler:

- **4.8 Arayüz tanımları ve korunması:** her işlem rol bazlı yetkilendirmeye sınırlanır, sunucu tarafında tekrar doğrulanır.
- **4.4 Beklemedeki veri:** stok ve denetim günlüğü SQLite'ta şifreli, doğrudan dosya düzenlemesiyle değiştirilemez.
- **4.9 Kod sağlamlaştırma:** istemci tarafı yetki kontrolleri sunucu tarafında da zorunlu kılınır (yalnız istemciye güvenilmez).
- **4.7 Varlık yönetimi:** kullanıcı-rol eşlemesi merkezi tutulur, işten ayrılan hesap anında iptal edilir.

Sunucu (localhost benzetimi): Rol ve yetki tablosunu tutar, yetkisiz işlemi ve imzasız onayı reddeder.

Genişletme: Kritik miktarların altına düşünce otomatik sipariş önerisi üreten basit bir kural motoru.

85 — Soğuk Zincir Sıcaklık Kaydedici

Kısa tanım: Nakliye sırasında sıcaklığı (sensör benzetimi) periyodik ölçüp imzalı günlük tutan bir kayıt cihazı istemcisi; gerçek sensöre bağlanılmaz. Taşıyıcı, sıcaklık ihlalini gizleyip sorumluluktan kaçınmak isteyebilir.

Temel özellikler: Periyodik sıcaklık örnekleme · Eşik aşımında alarm · İmzalı günlük tutma · Sevkiyat raporu dışı aktarma · Cihaz kalibrasyon bilgisi görüntüleme

Korunacak varlıklar:

- Sıcaklık günlüğü — **I+** (geçmişe dönük değiştirilemez)
- Kalibrasyon sertifikası — **I**
- Alarm eşiği yapılandırması — **I**
- Cihaz imzalama anahtarı — **C, I+**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** her ölçüm kaydı cihaz anahtarıyla imzalanır ve zincirlenir.
- **4.10 RASP:** cihaz kasası açılırsa (benzetim sinyali) kurcalama bayrağı işaretlenir ve günlük durdurulmaz.
- **4.4 Beklemedeki veri:** günlük dosyası şifreli ve ekleme-yalnız biçimde SQLite'ta tutulur.
- **4.6 Dinamik varlıkların korunması:** alarm eşiği yapılandırması çalışma zamanında yetkisiz değiştirilemez.

Sunucu (localhost benzetimi): Sevkiyat kimliğine göre günlük zincirini tutar, kopuk veya imzasız segmenti reddeder.

Genişletme: Birden çok sensörden gelen verileri tek sevkiyat raporunda birleştirme.

86 — Endüstriyel PLC Yapılandırma Aracı (Benzetim)



Kısa tanım: Endüstriyel bir PLC'nin (yazılım benzetimi, gerçek cihaza bağlanılmaz) ladder-logic yapılandırmasını hazırlayıp yükleyen bir mühendislik istasyonu istemcisi. Yetkisiz biri yapılandırmayı değiştirip üretim hattında tehlikeli bir duruma yol açmak isteyebilir.

Temel özellikler: Yapılandırma projesi oluşturma/düzenleme · Mühendis kimlik doğrulama · Yapılandırmayı cihaza yükleme (benzetim) · Sürüm geçmişi · Değişiklik onayı

Korunacak varlıklar:

- PLC yapılandırma dosyası — I+
- Mühendis kimlik bilgileri — C
- Yükleme (deploy) günlüğü — I+
- İmzalanmış yapılandırma paketi — I+

Öne çıkan gereksinimler:

- **4.1 Geliştirme ortamı güvenliği:** yapılandırma projeleri sürüm kontrollü ve imzalı olarak derlenir, geliştirici makinesi izole tutulur.
- **4.5 Statik varlıkların korunması:** yükleme paketi bütünlük özetiyle korunur, değiştirilmiş paket cihaza (benzetim) yüklenmez.
- **4.8 Arayüz tanımları ve korunması:** mühendislik istasyonu-PLC protokolü tanımlı komutlarla sınırlanır.
- **4.13 Sertifikasyon ve sızma testi planı:** endüstriyel kontrol sistemi senaryosu için ayrı bir test planı tanımlanır.

Sunucu (localhost benzetimi): Yüklenen yapılandırmaların imzasını ve sürümünü doğrular, imzasız yüklemeyi reddeder.

Genişletme: İki mühendisin onayını gerektiren kritik değişiklik akışı (four-eyes principle).

87 – SCADA Alarm İstemcisi (Benzetim)

Kısa tanım: Endüstriyel tesisteki alarm olaylarını (yazılım benzetimi) izleyip operatöre gösteren, onay/kapatma işlemi yapan bir istemci; gerçek SCADA altyapısına bağlanılmaz. Yetkisiz erişim, kritik alarmı gizleyip müdahaleyi geciktirmek isteyebilir.

Temel özellikler: Operatör oturum açma · Canlı alarm listesi · Alarm onaylama/kapatma · Olay geçmişi sorgulama · Öncelik/eşik yapılandırması

Korunacak varlıklar:

- Alarm olay akışı – I+
- Operatör kimlik bilgileri – C
- Alarm onay/kapatma günlüğü – I+
- Eşik yapılandırması – I

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** alarm akışı TLS ile ve düşük gecikmeli doğrulanmış kanaldan iletilir.
- **4.8 Arayüz tanımları ve korunması:** alarm onay komutu yalnız yetkili operatör oturumundan kabul edilir.
- **4.2 Kullanımdaki veri:** operatör kimlik bilgisi bellekte işlem süresince korunur, ekran görüntüsüne sızmaz.
- **4.13 Sertifikasyon ve sızma testi planı:** kritik altyapı benzetimi olduğu için ayrı bir sızma testi senaryosu tanımlanır.

Sunucu (localhost benzetimi): Alarm kuyruğunu ve onay durumunu tutar, yetkisiz onay isteğini reddeder.

Genişletme: Kapatılmayan kritik alarmlar için otomatik yükseltme (escalation) kuralı.

**88 – Tıbbi Cihaz Yapılandırma Benzetimi**

Kısa tanım: Bir tıbbi cihazın (ör. infüzyon pompası benzetimi) doz/parametre yapılandırmasını hazırlayan bir istemci; gerçek cihaza ya da gerçek hasta verisine bağlanılmaz, tüm hasta bilgileri ****sentetik****tir. Yetkisiz değişiklik hasta güvenliğini tehlikeye atacağı için erişim ve bütünlük kritik önemdedir.

Temel özellikler: Klinisyen kimlik doğrulama · Doz/parametre yapılandırma · Sınır değer denetimi (güvenli aralık) · Yapılandırmayı cihaza gönderme (benzetim) · Değişiklik geçmişi

Korunacak varlıklar:

- Doz/parametre yapılandırması – **I+**
- Klinisyen kimlik bilgileri – **C**
- Sentetik hasta kaydı – **C, I**
- Yapılandırma değişiklik günlüğü – **I+**

Öne çıkan gereksinimler:

- **4.13 Sertifikasyon ve sızma testi planı:** tıbbi cihaz yazılımı için düzenleyici (regülasyon benzeri) sızma testi planı hazırlanır.
- **4.9 Kod sağlamlaştırma:** güvenli doz aralığı denetimi istemci ve sunucu tarafında ayrı ayrı zorunlu kılınır.
- **4.10 RASP:** hata ayıklayıcı bağlantısı tespit edilince yapılandırma gönderimi engellenir.
- **4.4 Beklemedeki veri:** sentetik hasta kaydı ve yapılandırma geçmişi şifreli tutulur.

Sunucu (localhost benzetimi): Cihaz kimliğine göre son onaylı yapılandırmayı tutar, güvenli aralık dışı değeri reddeder.

Genişletme: Kritik parametre değişikliklerinde ikinci bir klinisyenin onayını zorunlu kılma.

**89 – İnsansız Hava Aracı Uçuş Planı İmzalayıcı**

Kısa tanım: İnsansız hava aracı (İHA/drone, yazılım benzetimi) için uçuş planını hazırlayıp dijital olarak imzalayan bir istemci; gerçek araca bağlanılmaz. Pilot ya da yetkisiz biri, izin verilen uçuş bölgesi dışına çıkacak bir planı gizlice değiştirmek isteyebilir.

Temel özellikler: Uçuş rotası çizimi/düzenleme · Yasaklı bölge (no-fly zone) denetimi · Plan imzalama · Telemetri günlüğü görüntüleme (benzetim) · Plan geçmiş sorgulama

Korunacak varlıklar:

- Uçuş planı – **I+** (imzalı, onaysız değiştirilemez)
- Pilot kimlik bilgileri – **C**
- İmzalama anahtarı – **C, I+**
- Telemetri günlüğü (benzetim) – **I+**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** uçuş planı pilotun özel anahtarıyla imzalanır, sunucu imzayı doğrular.
- **4.3 Aktarımdaki veri:** plan ve telemetri iletimi TLS ile korunur.
- **4.14 Binary uygulama koruması:** yasaklı bölge denetim mantığı atlatmaya karşı sertleştirilir.
- **4.8 Arayüz tanımları ve korunması:** plan gönderim API'si yalnız imzalı ve doğrulanmış planları kabul eder.

Sunucu (localhost benzetimi): Onaylı uçuş planlarını ve imzalarını tutar, yasaklı bölgeye giren veya imzasız planı reddeder.

Genişletme: Uçuş sırasında rota sapması tespit edilince otomatik iptal sinyali üretme (benzetim).

**90 — Güvenlik Kamerası Kayıt Arşivi**

Kısa tanım: Güvenlik kameralarından (yazılım benzetimi) gelen kayıtları arşivleyen, erişim yetkisine göre izletilebilen bir sistem. Yetkisiz biri kaydı silmek, değiştirmek ya da izinsiz izlemek isteyebilir; kanıt bütünlüğü (chain of custody) önemlidir.

Temel özellikler: Kamera kaydı alma (benzetim akış) · Arşivleme ve etiketleme · Rol tabanlı izleme yetkisi · Kayıt dışı aktarma (delil paketi) · Erişim günlüğü

Korunacak varlıklar:

- Video kayıtları — C, I+
- Erişim/izleme günlüğü — I+
- Dışa aktarılan delil paketi — I+
- Kamera kimlik sertifikaları — I

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** kayıtlar diskte AES-GCM ile şifreli tutulur, anahtar SoftHSM'de saklı.
- **4.7 Varlık yönetimi:** her kaydın kim tarafından, ne zaman erişildiği envanterde izlenir.
- **4.13 Sertifikasyon ve sızma testi planı:** delil bütünlüğü (chain of custody) senaryosu için ayrı test planı tanımlanır.
- **4.3 Aktarımdaki veri:** kamera-arşiv iletimi TLS ile ve karşılıklı kimlik doğrulamayla korunur.

Sunucu (localhost benzetimi): Kayıt bütünlük özetlerini ve erişim günlüğünü tutar, tutarsız dışı aktarma isteğini reddeder.

Genişletme: Dışa aktarılan delil paketine bağımsız doğrulanabilir bir zaman damgası ekleme.

**91 – P Otopark Giriş-Çıkış Sistemi**

Kısa tanım: Plaka/bilet okuma (benzetim) ile giriş-çıkışı yöneten, ücretlendirme yapan bir otopark istemcisi. Kullanıcı ya da görevli, süreyi kısa göstererek veya bileti kopyalayarak ücret ödemekten kaçınmak isteyebilir.

Temel özellikler: Giriş bileti üretme · Çıkışta süre/ücret hesaplama · Ödeme alma (benzetim) · Bariyer açma komutu · Giriş-çıkış günlüğü

Korunacak varlıklar:

- Bilet kimliği ve giriş zamanı — **I+**
- Ödeme işlemi verisi — **C, I**
- Bariyer açma komutu — **I+**
- Giriş-çıkış günlüğü — **I+**

Öne çıkan gereksinimler:

- **4.9 Kod sağlamlaştırma:** süre/ücret hesaplama mantığı istemci tarafında kolayca değiştirilemeyecek şekilde sağlamlaştırılır.
- **4.8 Arayüz tanımları ve korunması:** bariyer açma komutu yalnız geçerli ödeme onayından sonra üretilir, doğrudan çağrılmaz.
- **4.6 Dinamik varlıkların korunması:** bilet kimliği tahmin edilemez biçimde üretilir, kopyalanan bilet reddedilir.
- **4.4 Beklemedeki veri:** giriş-çıkış günlüğü şifreli ve değiştirilemez biçimde tutulur.

Sunucu (localhost benzetimi): Açık biletleri ve ödeme durumunu tutar, tekrar kullanılan veya ödenmemiş bileti reddeder.

Genişletme: Aylık abonelik plakaları için otomatik geçiş ve ayrı bir yetkilendirme akışı.

**92 – Otel Kapı Kartı Kodlayıcı Benzetimi**

Kısa tanım: Otel resepsiyonunda misafir kapı kartını (RFID benzetimi) kodlayan, süreli erişim tanımlayan bir istemci; gerçek kart donanımına bağlanılmaz. Resepsiyon yazılımına sızan biri, süresi geçmiş ya da başka odaya geçerli kart üretmek isteyebilir.

Temel özellikler: Rezervasyon eşleştirme · Kart kodlama (oda + süre) · Kartı iptal etme/yeniden kodlama · Ana kart (master) işlemleri · Kart kullanım günlüğü

Korunacak varlıklar:

- Kart erişim anahtarı – **C, I+**
- Ana (master) anahtar – **C, I+**
- Oda-süre yapılandırması – **I**
- Kart kullanım günlüğü – **I+**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** kart anahtarı oda ve geçerlilik süresinden türetilir, ana anahtar SoftHSM'de saklı tutulur.
- **4.4 Beklemedeki veri:** kodlama geçmişi ve anahtar türetme parametreleri şifreli SQLite'ta tutulur.
- **4.14 Binary uygulama koruması:** kart kodlama mantığı tersine mühendislikle ana anahtarı ifşa etmeyecek şekilde korunur.
- **4.10 RASP:** hata ayıklayıcı tespit edilince ana anahtar işlemleri durdurulur.

Sunucu (localhost benzetimi): Aktif kartların oda/süre bilgisini tutar, süresi dolmuş veya iptal edilmiş kartı reddeder.

Genişletme: Kayıp kart bildirildiğinde tüm kilitlere (benzetim) anlık iptal sinyali yayma.

93 – Yetkili Restoran Sipariş ve Mutfak Ekranı

Kısa tanım: Garsonların sipariş girdiği, mutfakın gördüğü, rol bazlı yetkilendirilmiş bir sipariş sistemi. Yetkisiz bir kullanıcı siparişi ya da ödeme tutarını değiştirip zimmet (iç hırsızlık) yapmak isteyebilir.

Temel özellikler: Rol tabanlı oturum açma (garson/mutfak/yönetici) · Sipariş oluşturma-iptal · Mutfak ekranı senkronizasyonu · Hesap kapatma/ödeme · İndirim/iptal onay zinciri

Korunacak varlıklar:

- Sipariş ve hesap kayıtları – **I+**
- İndirim/iptal onay günlüğü – **I+**
- Ödeme bağlantısı token'ı – **C**
- Kullanıcı rol bilgisi – **C, I**

Öne çıkan gereksinimler:

- **4.8 Arayüz tanımları ve korunması:** iptal/indirim işlemleri yalnız yetkili rolden ve sunucu tarafında tekrar doğrulanarak kabul edilir.
- **4.2 Kullanımdaki veri:** ödeme token'ı yalnız ödeme anında bellekte açık tutulur.
- **4.7 Varlık yönetimi:** personel hesapları ve rolleri merkezi listede tutulur, vardiya sonunda oturum kapanır.
- **4.9 Kod sağlamlaştırma:** fiyat/indirim hesaplaması istemci tarafında manipülasyona karşı sağlamlaştırılır.

Sunucu (localhost benzetimi): Açık hesapları ve onay zincirini tutar, yetkisiz indirim/iptal isteğini reddeder.

Genişletme: Vardiya sonu Z raporu ile beklenen/gerçekleşen tutarların karşılaştırılması.

**94 – Bordro Kasası**

Kısa tanım: Çalışan maaş bilgilerini ve bordro geçmişini saklayan, yalnız yetkili İK/muhasebe personelinin erişebildiği bir kasa uygulaması. İçeriden erişimi olan biri kendi maaşını değiştirmek ya da başkalarının bordro bilgisine izinsiz bakmak isteyebilir.

Temel özellikler: Yetkili personel oturum açma · Bordro kaydı girme/görüntüleme · Maaş hesaplama (kesinti/vergi benzetimi) · Onay zinciriyle ödeme talimatı · Erişim/görüntüleme günlüğü

Korunacak varlıklar:

- Maaş/bordro kayıtları – C, I
- Çalışan kimlik bilgileri – C
- Ödeme talimatı – I+
- Erişim günlüğü – I+

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** bordro kayıtları SQLite'ta alan bazlı şifreli tutulur, yalnız yetkili anahtarla çözülür.
- **4.2 Kullanımdaki veri:** maaş verisi ekranda yalnız yetkili oturumda ve gerektiği kadar gösterilir.
- **4.11 Bellek koruması:** maaş hesaplama sırasında kullanılan geçici değerler işlem sonrası güvenli silinir.
- **4.7 Varlık yönetimi:** kimin hangi bordroya erişebileceği rol bazlı envanterde tanımlanır.

Sunucu (localhost benzetimi): Onaylanmış ödeme talimatlarını tutar, yetkisiz veya imzasız talimatı reddeder.

Genişletme: Maaş değişikliklerinde ikinci bir yetkilinin onayını zorunlu kılan dört-göz (four-eyes) akışı.

95 – Kurumsal VPN Yapılandırma İstemcisi

Kısa tanım: Çalışanların kurumsal ağa VPN ile bağlanmasını sağlayan yapılandırma istemcisi; gerçek bir VPN sunucusuna değil, localhost benzetim sunucusuna bağlanır. Çalınmış bir dizüstü bilgisayar üzerinden saldırgan, VPN kimlik bilgilerini kullanarak ağa sızmak isteyebilir.

Temel özellikler: Kullanıcı kimlik doğrulama (parola + ikinci faktör benzetimi) · Yapılandırma profili indirme · Bağlantı kurma/kesme · Sertifika yenileme · Bağlantı günlüğü

Korunacak varlıklar:

- VPN kimlik bilgileri – **C**
- İstemci sertifikası ve özel anahtarı – **C, I+**
- Yapılandırma profili – **I**
- Bağlantı günlüğü – **I+**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** istemci sertifikası SoftHSM'de sarılı tutulur, sunucu karşılıklı TLS ile doğrular.
- **4.3 Aktarımdaki veri:** tüm bağlantı kurulumu ve trafiği TLS 1.3 üzerinden yapılır.
- **4.1 Geliştirme ortamı güvenliği:** test/geliştirme sertifikaları üretim yapılandırmasına karışmaz.
- **4.5 Statik varlıkların korunması:** yapılandırma profili dosyası bütünlük imzasıyla korunur, değiştirilmiş profil reddedilir.

Sunucu (localhost benzetimi): Geçerli sertifikaları ve aktif oturumları tutar, süresi dolmuş veya iptal edilmiş sertifikayı reddeder.

Genişletme: Şüpheli konumdan bağlanma denemesinde ek doğrulama isteyen basit bir risk kuralı.

96 – Olay Günlüğü Toplayıcı Ajan

Kısa tanım: Farklı bileşenlerden (uygulama/sistem benzetimi) güvenlik olay günlüklerini toplayıp değiştirilemez biçimde merkezi sunucuya ileten bir ajan. Sisteme sızan bir saldırgan, izlerini gizlemek için günlük kayıtlarını silmek ya da değiştirmek ister.

Temel özellikler: Günlük kaynaklarını izleme · Yerel arabellekte biriktirme · İmzalı toplu gönderim · Gönderim onayı (ack) takibi · Kesinti sonrası devam etme

Korunacak varlıklar:

- Ham günlük kayıtları – **I+** (ekleme-yalnız, değiştirilemez)
- Ajan kimlik sertifikası – **I**
- İletim sırası/sayaç – **I+**
- Yerel arabellek – **C, I**

Öne çıkan gereksinimler:

- **4.4 Beklemedeki veri:** yerel arabellek şifreli ve ekleme-yalnız biçimde tutulur, geriye dönük düzenleme engellenir.
- **4.9 Kod sağlamlaştırma:** ajan binary dosyası günlük gizleme/temizleme amaçlı yama girişimine karşı sağlamlaştırılır.
- **4.6 Dinamik varlıkların korunması:** çalışma zamanında ajan sürecine kod enjeksiyonu tespit edilir.
- **4.15 OWASP ve derleme/dağıtım hattı:** ajan derleme hattında bağımlılık taraması ve imzalı yayınlama zorunludur.

Sunucu (localhost benzetimi): Ajan başına son alınan sıra numarasını tutar, sıra atlayan veya imzasız toplu gönderimi reddeder.

Genişletme: Beklenen aralıkta veri göndermeyen ajanlar için "sessiz kalma" (heartbeat kaybı) uyarısı.

**97 – Sahte Parça Doğrulayıcı**

Kısa tanım: Endüstriyel/otomotiv yedek parçaların (yazılım benzetimi) üzerindeki dijital imzalı seri numarasını okuyup üreticinin imzasını doğrulayan bir istemci. Sahte parça üreticisi, gerçek bir imzayı taklit etmek ya da kopyalamak isteyebilir.

Temel özellikler: Parça seri numarası okuma (barkod/kod benzetimi) · İmza doğrulama · Üretici kayıt sorgulama · Şüpheli/sahte parça işaretleme · Tarama geçmişi

Korunacak varlıklar:

- Üretici doğrulama sertifikası – I
- Parça seri numarası ve imzası – I+
- Tarama geçmişi – I+
- Doğrulama anahtarı – C, I+

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** her parça üreticinin özel anahtarıyla imzalanır, istemci yalnız genel anahtarla doğrular.
- **4.5 Statik varlıkların korunması:** doğrulama anahtarı/sertifika deposu değiştirilmeye karşı bütünlük denetimiyle korunur.
- **4.14 Binary uygulama koruması:** doğrulama mantığı, sahte "her zaman geçerli" yamasına karşı sertleştirilir.
- **4.8 Arayüz tanımları ve korunması:** tarama sonucu API'si yalnız tanımlı doğrulama kodlarını döndürür.

Sunucu (localhost benzetimi): Bilinen seri numaralarını ve imza durumlarını tutar, daha önce iptal edilmiş parçayı reddeder.

Genişletme: Aynı seri numarasının birden çok yerde tarandığını tespit eden bir kopya-parça uyarısı.

98 — Laboratuvar Numune Gözetim Zinciri

Kısa tanım: Laboratuvara gelen numunelerin alınışından sonuç raporuna kadar her elden geçişini imzalı biçimde kaydeden bir gözetim zinciri (chain of custody) sistemi; hastalara ait veriler yalnız **sentetik**tir. Yetkisiz biri numune kaydını değiştirerek zincirdeki bir adımı gizlemek isteyebilir.

Temel özellikler: Numune kabul ve etiketleme (benzetim barkod) · Elden ele teslim kaydı · Teknisyen kimlik doğrulama · Sonuç girişi ve raporlama · Zincir geçmişi sorgulama

Korunacak varlıklar:

- Gözetim zinciri kayıtları — **I+** (imzalı, kronolojik)
- Sentetik hasta/numune verisi — **C, I**
- Teknisyen kimlik bilgileri — **C**
- Sonuç raporu — **I+**

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** her elden geçiş kaydı ilgili teknisyenin anahtarıyla imzalanıp zincire eklenir.
- **4.4 Beklemedeki veri:** zincir kayıtları ekleme-yalnız biçimde şifreli SQLite'ta tutulur.
- **4.13 Sertifikasyon ve sızma testi planı:** adli/hukuki geçerlilik gerektiren bir sistem olduğu için ayrı bir doğrulama ve sızma testi planı tanımlanır.
- **4.7 Varlık yönetimi:** teknisyen kimlikleri ve yetki kapsamaları merkezi listede tutulur.

Sunucu (localhost benzetimi): Numune başına zincir bütünlüğünü doğrular, kopuk veya imzasız halkayı reddeder.

Genişletme: Zincirdeki her adımı bağımsız doğrulanabilir bir özet (hash) ile dışa aktarma.

**99 – Akıllı Tarım Sensör Ağ Geçidi**

Kısa tanım: Tarladaki nem/sıcaklık sensörlerinden (yazılım benzetimi) veri toplayıp bir ağ geçidi üzerinden merkezi sunucuya ileten bir sistem; gerçek sensöre bağlanılmaz. Ağ geçidine sızan biri, sahte sensör verisi enjekte edip sulama/gübreleme kararlarını bozmak isteyebilir.

Temel özellikler: Sensör kaydı/eşleştirme · Periyodik ölçüm toplama · Yerel önbellekte biriktirme · Sunucuya toplu iletim · Sensör durumu izleme

Korunacak varlıklar:

- Sensör ölçüm verisi – I
- Sensör eşleştirme anahtarları – C, I+
- Ağ geçidi ürün yazılımı – I+
- Yerel önbellek – C, I

Öne çıkan gereksinimler:

- **4.3 Aktarımdaki veri:** sensör-ağ geçidi ve ağ geçidi-sunucu iletimi şifreli kanaldan yapılır.
- **4.7 Varlık yönetimi:** kayıtlı sensörlerin kimlik ve anahtar envanteri tutulur, tanımsız sensör verisi reddedilir.
- **4.6 Dinamik varlıkların korunması:** çalışma zamanında sahte sensör kaydı (spoofing) girişimi tespit edilir.
- **4.1 Geliştirme ortamı güvenliği:** ağ geçidi ürün yazılımı imzalı derleme hattından üretilir.

Sunucu (localhost benzetimi): Kayıtlı sensör kimliklerini ve son ölçümleri tutar, eşleşmemiş sensörden gelen veriyi reddeder.

Genişletme: Anormal ölçüm örüntülerinde (ani sıçrama) basit bir anomali uyarısı üretme.

**100 — Kişisel Anahtar ve Sertifika Yöneticisi**

Kısa tanım: Kullanıcının kişisel özel anahtarlarını, sertifikalarını ve parolalarını tek bir güvenli kasada tutan, imzalama/şifreleme işlemlerine aracılık eden bir yönetici uygulaması; dönemin diğer 99 projesinin temelindeki anahtar yönetimi düşüncesini tek başına somutlaştırır. Cihazı ele geçiren bir saldırgan tüm anahtarları ele geçirmek ister.

Temel özellikler: Anahtar çifti üretme · Sertifika isteği (CSR) oluşturma ve içe aktarma · İmzalama/şifre çözme aracılığı (özel anahtar hiç dışarı çıkmaz) · Anahtar/sertifika yenileme ve iptal · Yedekleme (şifreli)

Korunacak varlıklar:

- Özel anahtarlar — C, I+
- Sertifikalar — I
- Ana parola/anahtar (master) — C, I+
- Yedekleme dosyası — C, I+

Öne çıkan gereksinimler:

- **4.12 Kriptografi ve sertifikalar:** tüm anahtar üretimi/saklama [SoftHSM/PKCS#11](#) üzerinden yapılır, özel anahtar uygulama belleğine asla açık çıkmaz.
- **4.4 Beklemedeki veri:** sertifika meta verisi ve yedekleme dosyası AES-GCM ile şifreli tutulur.
- **4.11 Bellek koruması:** imzalama işlemi sırasında kullanılan ara değerler işlem sonrası güvenli silinir.
- **4.14 Binary uygulama koruması:** uygulama tersine mühendislikle ana parolayı/anahtarı ifşa etmeyecek şekilde sertleştirilir.
- **4.10 RASP:** hata ayıklayıcı bağlantısı tespit edilince kasa kilitlenir, işlemler reddedilir.

Sunucu (localhost benzetimi): Sertifika iptal listesini (CRL benzetimi) ve yenileme isteklerini tutar, süresi dolmuş sertifikayı reddeder.

Genişletme: Birden çok cihaz arasında anahtar kasasının şifreli senkronizasyonu.